ПЛАТФОРМА ПРОВЕРКИ КОМПЕТЕНЦИЙ

специалистов по информационной безопасности

Пояснительная записка к концепции продукта

Этап: теоретическая проработка и proof of concept

Основание: Положение об отраслевом центре компетенций по информационной безопасности в промышленности (приложение № 1 к протоколу от 24 ноября 2023 г.)

Профессиональные стандарты: 06.030, 06.032, 06.033, 06.034, 06.053

Нотации: ГОСТ 19.701-90, UML 2.5, IDEF0 (Р 50.1.028-2001), DFD, ER

Редакция: 1.0

2026

СОДЕРЖАНИЕ

ПЕРЕЧЕНЬ СОКРАЩЕНИЙ....4
ВВЕДЕНИЕ....5
1 АНАЛИЗ ПРЕДМЕТНОЙ ОБЛАСТИ И ТРЕБОВАНИЙ....6
1.1 Назначение продукта и заинтересованные стороны....6
1.2 Требования Положения об ОЦК....6
1.3 Профессиональные стандарты и уровни....7
1.4 Анализ аналогов....8
1.5 Состояние прототипа и выявленные ограничения....9
2 КОНЦЕПЦИЯ ПРОДУКТА....10
2.1 Два контура: компания и ОЦК....10
2.2 Роли и права....10
2.3 Модель проверки....11
2.4 Модель итоговой оценки....12
3 ФУНКЦИОНАЛЬНАЯ МОДЕЛЬ....14
3.1 Функциональная модель IDEF0....14
3.2 Диаграммы потоков данных....17
3.3 Варианты использования....19
4 СХЕМЫ АЛГОРИТМОВ (ГОСТ 19.701-90)....21
4.1 Алгоритм прохождения проверки....21
4.2 Алгоритм ситуационной задачи....22
4.3 Алгоритм расчёта итоговой оценки....24
4.4 Алгоритм проверки сертификатов по открытым источникам....25
4.5 Алгоритм оценки ревьюером....26
4.6 Алгоритм входа и выбора роли....26
5 ПОВЕДЕНЧЕСКИЕ МОДЕЛИ (UML)....28
5.1 Диаграммы последовательности....28
5.2 Диаграммы состояний....32
6 МОДЕЛЬ ДАННЫХ....35
7 АРХИТЕКТУРА И БЕЗОПАСНОСТЬ....40
7.1 Компоненты....40
7.2 Развёртывание....43
7.3 Безопасность и персональные данные....44
7.4 Программный интерфейс (эскиз)....45
8 ИНТЕРФЕЙС....46
8.1 Принципы единой оболочки....46
8.2 Макеты экранов....46
9 ПЛАН РЕАЛИЗАЦИИ И РИСКИ....54
9.1 Этапы....54

9.2 Критерии готовности PoC.....54
9.3 Риски.....55
ЗАКЛЮЧЕНИЕ.....56
ПРИЛОЖЕНИЕ А. ПРИМЕР СИТУАЦИОННОЙ ЗАДАЧИ.....57

ПЕРЕЧЕНЬ СОКРАЩЕНИЙ

Таблица 1 — Сокращения и термины

Сокращение	Расшифровка
ИБ	Информационная безопасность
ОЦК	Отраслевой центр компетенций по информационной безопасности в промышленности
ПС	Профессиональный стандарт (06.030, 06.032, 06.033, 06.034, 06.053)
ОТФ / ТФ	Обобщённая трудовая функция / трудовая функция профессионального стандарта (например, A/01.5 — ТФ уровня квалификации 5)
Компетенция	Элемент ТФ: необходимое знание, умение или трудовое действие. Тема — смысловой узел (например, «Криптография и СКЗИ»), к которому привязаны компетенции и задачи
Ситуационная задача	Задача-сценарий из нескольких шагов с материалами (журналы, схемы, конфигурации), в которой проверяются действия специалиста, а не память
Разминка	Короткий тест на знания (по умолчанию 15 вопросов) перед ситуационными задачами
Рубрика	Перечень критериев с баллами для оценки развёрнутого ответа
КИИ	Критическая информационная инфраструктура
ПДн	Персональные данные
АСУ ТП	Автоматизированная система управления технологическим процессом
СКЗИ	Средство криптографической защиты информации
SIEM	Система управления событиями ИБ
OSINT	Разведка по открытым источникам; здесь — поиск публичных профилей и сертификатов кандидата
AI-резюме	Структурированная характеристика кандидата, подготовленная языковой моделью и проверяемая ревьюером
PoC	Proof of concept — демонстрационный прототип
DFD	Data Flow Diagram — диаграмма потоков данных
IDEF0	Методология функционального моделирования (Р 50.1.028-2001)
UML	Унифицированный язык моделирования
ER	Модель «сущность — связь»
ЦОД	Центр обработки данных
KMS	Сервис управления ключами шифрования

ВВЕДЕНИЕ

Настоящая пояснительная записка описывает целевой облик платформы проверки компетенций специалистов по информационной безопасности. Документ подготовлен на этапе теоретической проработки: программный код на этом этапе не меняется, а результатом являются модели, схемы алгоритмов и макеты интерфейса, по которым будет вестись разработка.

Действующий прототип уже умеет: регистрировать кандидатов и ревьюеров, проводить тест по одному из пяти профессиональных стандартов, искать сертификаты кандидата в открытых источниках (Credly, Sherlock), показывать требования должностей в виде индекса «должность — трудовая функция — компетенция — тема», рассчитывать итоговую оценку 0–100 и формировать AI-резюме кандидата (через API или вручную через внешний чат-ассистент).

Концепция развивает прототип в трёх направлениях:

- **Единая оболочка интерфейса** по образцу PortSwigger Web Security Academy: одно верхнее меню, боковая навигация внутри раздела, всегда видимый прогресс. Состав меню зависит от роли пользователя, а текущая роль явно показана в шапке.
- **Ситуационные задачи вместо случайных вопросов.** Проверка состоит из короткой разминки на знания и нескольких многошаговых сценариев с материалами. Ошибка на критическом шаге показывает кандидату последствия его решения.
- **Модуль аналитики ОЦК.** Обезличенные агрегаты по организациям и направлениям деятельности ОЦК: тепловая карта дефицита компетенций, потребность в подготовке кадров, план обучения. Модуль поддерживает функции 3.1.19 и 3.1.20 Положения об ОЦК.

Продукт рассматривается в двух контурах: как инструмент компании (найм и оценка своих сотрудников) и как отраслевой инструмент ОЦК (сводная картина по организациям промышленности). Ядро у контуров общее, различаются роли и уровень доступа к данным.

Структура документа: раздел 1 — анализ предметной области и требований; раздел 2 — концепция продукта, роли и модель проверки; раздел 3 — функциональная модель (IDEF0, DFD, варианты использования); раздел 4 — схемы алгоритмов по ГОСТ 19.701-90; раздел 5 — поведенческие UML-модели; раздел 6 — модель данных; раздел 7 — архитектура и безопасность; раздел 8 — интерфейс; раздел 9 — план реализации и риски. В приложении А приведён полный пример ситуационной задачи.

1 АНАЛИЗ ПРЕДМЕТНОЙ ОБЛАСТИ И ТРЕБОВАНИЙ

1.1 Назначение продукта и заинтересованные стороны

Платформа предназначена для объективной и объяснимой оценки квалификации специалистов по ИБ относительно требований профессиональных стандартов и для планирования их обучения. Объективность обеспечивается проверкой действий в реалистичных ситуациях и подтверждёнными сертификатами; объяснимость — тем, что каждый балл итоговой оценки можно проследить до конкретного ответа, шага или сертификата.

Таблица 2 — Заинтересованные стороны

Сторона	**Что получает от платформы**
Кандидат (соискатель)	Понятные требования к должности, прохождение проверки, результат с разбором сильных и слабых сторон
Сотрудник организации	Регулярную самопроверку, карту своих компетенций, рекомендации по обучению в Академии
Ревьюер (эксперт, руководитель ИБ)	Очередь на оценку, карточку кандидата с итоговой оценкой и AI-резюме, оценку развёрнутых ответов по рубрике, решение по кандидату
Методист	Редактор ситуационных задач и рубрик, привязку задач к ТФ и темам, статистику сложности задач
Аналитик ОЦК	Обезличенную картину дефицита компетенций по организациям и направлениям, исходные данные для планов подготовки кадров
Администратор	Управление учётными записями и ролями, журнал доступа к персональным данным

1.2 Требования Положения об ОЦК

Положение об ОЦК определяет задачи, функции и структуру центра. Для платформы значимы задачи и функции, связанные с кадрами и образованием, а также направления деятельности заместителей руководителя (п. 4.3.1), которые используются как вторая ось классификации задач — наряду с профессиональными стандартами.

Таблица 3 — Соответствие положений ОЦК возможностям платформы

Пункт Положения	Содержание (кратко)	Чем поддерживается в платформе
2.1.6	Мероприятия по повышению уровня образования в сфере ИБ работников субъектов промышленности	Академия: траектории по должностям, темы с объяснениями и задачами, рекомендации по слабым темам
2.1.4	Сбор и анализ данных о состоянии ИБ	Обезличенные агрегаты результатов проверок по организациям как индикатор кадровой составляющей ИБ
3.1.14	Анализ и оценка эффективности деятельности по обеспечению ИБ, отчёты	Отчёты модуля аналитики: динамика по кварталам, сравнение организаций
3.1.17	Моделирование угроз, ведение баз данных	Отдельная группа ситуационных задач на моделирование угроз объектов КИИ
3.1.18	Учебно-методические мероприятия (сборы, семинары)	Подбор задач и тем для мероприятий по выявленным дефицитам
3.1.19	Разработка учебных программ, повышение квалификации и переподготовка кадров	Потребность в подготовке по направлениям; привязка тем к программам обучения
3.1.20	Оценка потребности в кадрах, отраслевые планы целевой подготовки	Таблица «нужно обучить: направление — количество — срок», выгрузка для плана
4.3.1.1–4.3.1.6, 4.3.1.8	Направления деятельности: защита конфиденциальной информации и ПДн; безопасность КИИ; обнаружение атак и реагирование на инциденты; режим секретности; противодействие иностранным техническим разведкам; техническая защита гостайны; подготовка кадров	Справочник «Направления ОЦК» — фильтр каталога задач и столбцы тепловой карты аналитики
5.1.2	Право запрашивать у организаций сведения, необходимые для выполнения функций	Организации передают ОЦК только агрегаты; персональные данные остаются в контуре организации

1.3 Профессиональные стандарты и уровни

Требования к должностям берутся из пяти профессиональных стандартов. Каждый стандарт раскладывается на обобщённые трудовые функции, трудовые функции и элементы (знания, умения, трудовые действия); элементы связаны с темами по правилам сопоставления, что позволяет для любой темы показать, где она требуется, и наоборот.

Таблица 4 — Профессиональные стандарты

Код	Наименование
06.030	Специалист по защите информации в телекоммуникационных системах и сетях
06.032	Специалист по безопасности компьютерных систем и сетей
06.033	Специалист по защите информации в автоматизированных системах
06.034	Специалист по технической защите информации
06.053	Специалист по информационной безопасности в кредитно-финансовой сфере

Уровни квалификации ТФ (5–8) сведены в три понятных пользователю уровня задач. Разбиение предварительное и может уточняться методистами.

Таблица 5 — Уровни задач

Уровень задачи	Уровни квалификации ТФ	Что проверяет
Базовый	5–6	Выполнение типовых действий по инструкции: распознать инцидент, выбрать правильную меру, не допустить грубой ошибки
Специалист	7	Самостоятельный анализ: найти причину по журналам, выбрать решение из нескольких допустимых, обосновать
Эксперт	8	Проектирование и управление: модель угроз, архитектура защиты, оценка рисков, решения в условиях неполной информации

1.4 Анализ аналогов

Основным ориентиром по интерфейсу выбрана PortSwigger Web Security Academy. Её сильные стороны, которые переносятся в платформу:

- одна оболочка для всего обучения: верхнее меню разделов и боковое меню внутри раздела, пользователь никогда не теряет контекст;
- связка «тема — объяснение — задачи»: после чтения теории сразу доступны практические задачи по ней;
- наглядные уровни (Apprentice / Practitioner / Expert) и статус «решено / не решено» у каждой задачи;
- задачи проверяют умение действовать, а не память: результат засчитывается за верное действие в реалистичной обстановке.

Отличия платформы от аналога: задачи привязаны к трудовым функциям профессиональных стандартов, результат выражается итоговой оценкой с разложением, есть роли оценки (ревьюер) и обезличенной аналитики (ОЦК), а сертификаты кандидата подтверждаются по открытым источникам.

1.5 Состояние прототипа и выявленные ограничения

Таблица 6 — Что есть в прототипе и что меняется

Возможность	Сейчас	В целевой концепции
Навигация	Отдельные страницы: тест, кабинет, требования, панель ревьюера	Единая оболочка; меню и вкладки по роли; бейдж «Вы вошли как»
Проверка	Случайная выборка вопросов с выбором ответа + одно кейс-задание	Разминка (15 вопросов) + несколько ситуационных задач по 3–6 шагов
Требования	Вкладка «Требования»: индекс стандарт → ТФ → компетенция → тема	Академия: тот же индекс, дополненный объяснениями, задачами и прогрессом
Оценка	0–100: знания 45, темп 5, практика 35, сертификаты 15	Та же формула; знания учитывают и автопроверяемые шаги задач
Сертификаты	Credly + Sherlock, подтверждение ревьюером	Без изменений; добавлен жизненный цикл сертификата (рис. 16)
AI-резюме	Через API или вручную через внешний ассистент	Без изменений; добавлена проверка ответа по схеме
Аналитика	Нет	Модуль аналитики ОЦК на обезличенных агрегатах
Методический контур	Вопросы в JSON-файлах	Редактор задач и рубрик с привязкой к ТФ и темам

2 КОНЦЕПЦИЯ ПРОДУКТА

2.1 Два контура: компания и ОЦК

Контур компании. Организация разворачивает платформу у себя (или пользуется отраслевым экземпляром) и проверяет кандидатов и сотрудников. Персональные данные, ответы и оценки хранятся в контуре организации и доступны ревьюерам этой организации.

Контур ОЦК. Из контура компании в ОЦК уходят только агрегаты: по организации, направлению ОЦК, уровню и периоду — доли специалистов ниже требуемого уровня и численность групп. Минимальный размер группы для показа (по умолчанию 5 человек) исключает восстановление личности по агрегату. Аналитик ОЦК не видит ФИО, контактов и ответов.

2.2 Роли и права

Роль определяет состав меню. Вкладка «Ревьюер» есть только у пользователя с ролью ревьюера, «Аналитика ОЦК» — только у аналитика. Один пользователь может иметь несколько ролей; тогда после входа он выбирает роль, а переключение доступно из бейджа «Вы вошли как: <роль> ▼» в правом верхнем углу. Бейдж виден на каждом экране, поэтому пользователь всегда знает, в какой роли действует.

Таблица 7 — Матрица ролей и прав

Действие / данные	Кандидат	Сотрудник	Ревьюер	Методист	Аналитик ОЦК	Админ
Академия, каталог задач	✓	✓	✓	✓	✓	✓
Проходить проверку	✓	✓	—	предпросмотр	—	—
Видеть свои результаты	✓	✓	—	—	—	—
Видеть ПДн и ответы кандидатов	—	—	своей организации	—	—	по журналу
Оценивать ответы, подтверждать сертификаты	—	—	✓	—	—	—
Принимать решение по кандидату	—	—	✓	—	—	—
Создавать задачи и рубрики	—	—	—	✓	—	—
Обезличенная аналитика	—	—	своя организация	статистика задач	все организации	—
Управлять ролями	—	—	—	—	—	✓

Чаще всего путают роли ревьюера и аналитика ОЦК. Различие принципиальное:

Таблица 8 — Ревьюер и аналитик ОЦК

Признак	**Ревьюер**	**Аналитик ОЦК**
Объект работы	Конкретный кандидат или сотрудник	Организация, отрасль, направление
Доступ к ПДн	Да, в пределах своей организации	Нет — только обезличенные агрегаты
Действия	Оценивает ответы, подтверждает сертификаты, принимает решение	Только чтение: смотрит срезы, выгружает отчёты
Результат работы	Решение по человеку (принять, развивать, отказать)	План подготовки кадров, предложения по обучению (п. 3.1.19, 3.1.20)
Где работает	Контур компании	Контур ОЦК

2.3 Модель проверки

Проверка строится вокруг ситуационных задач. Случайный тест сохраняется только как короткая разминка: он быстро показывает уровень знаний и даёт данные для калибровки сложности.

1) **Вход и выбор должности.** Пользователь входит, выбирает профессиональный стандарт; при первой проверке запускается поиск сертификатов по открытым источникам.
2) **Самооценка (по желанию).** Кандидат оценивает себя по темам; в балл не входит, но показывает, насколько реалистично человек себя оценивает.
3) **Разминка.** 15 вопросов с выбором ответа по темам должности (число настраивается).
4) **Ситуационные задачи.** Подбор M задач (по умолчанию 3–4) по ТФ должности и уровню; каждая задача — сценарий, материалы и 3–6 шагов.
5) **Развёрнутый ответ (кейс).** Последний шаг одной из задач — текст (например, отчёт об инциденте), который оценивает ревьюер по рубрике.
6) **Предварительная оценка.** Сразу после отправки рассчитывается итоговая оценка с признаком «предварительно» до оценки ревьюером.

Таблица 9 — Типы шагов ситуационной задачи

Тип шага	Что делает кандидат	Проверка
Выбор	Выбирает один или несколько вариантов (например, значимые признаки атаки)	Автоматически; частичный балл за частично верный набор
Порядок	Расставляет действия в порядке выполнения	Автоматически; балл по числу верных пар (тау Кендалла)
Поиск ошибки	Указывает строку журнала или правила конфигурации с ошибкой	Автоматически, по номеру строки
Значение	Вводит короткое значение: IP-адрес, порт, имя учётной записи	Автоматически, по шаблону
Текст	Пишет развёрнутый ответ	Ревьюер по рубрике; до его оценки — AI-оценка полноты с пометкой «предварительно»
Последствие	Получает изменившуюся ситуацию после ошибки на критическом шаге и действует в ней	Как у шага выбранного типа; показывает, умеет ли кандидат исправлять ошибки

Критический шаг и последствие. Методист может пометить шаг как критический. Если кандидат ошибся на нём, перед следующим шагом вставляется шаг-последствие: например, вместо изоляции АРМ кандидат выбрал «понаблюдать», и в следующем журнале видно, что атака распространилась на соседний сегмент. Так проверяется не только знание правильного ответа, но и способность исправлять ситуацию.

2.4 Модель итоговой оценки

Итоговая оценка — одно число от 0 до 100 с разложением на компоненты. Шкала 0–100 выбрана сознательно: проверка не различает людей точнее нескольких баллов из ста, более мелкая шкала изображала бы несуществующую точность. Формула детерминирована; AI влияет на оценку только временно, пока ревьюер не оценил развёрнутый ответ.

Таблица 10 — Компоненты итоговой оценки

Компонент	**Максимум**	**Расчёт**
Знания	45	Доля верных ответов разминки и автопроверяемых шагов с весом 1 + d, где d ∈ [0; 1] — сложность. Априорно d задаётся уровнем ТФ (5 → 0, 8 → 1) и по мере накопления ответов смешивается с наблюдаемой долей ошибок (байесовское сглаживание, сила априорной оценки — 20 ответов)
Темп	5	5 · (1 − доля ответов быстрее 3 секунд). Штрафует угадывание, а не медленную работу
Практика	35	35 · средняя оценка развёрнутых ответов по рубрикам / 100. До оценки ревьюера — AI-оценка полноты с признаком «предварительно»
Сертификаты	15	min(15; Σ баллы уровня · (0,25 + 0,75 · релевантность)). Баллы уровня: entry 3, associate 5, professional 8, expert 12; релевантность — доля тем сертификата, нужных должности. Учитываются только подтверждённые сертификаты

Если компонент недоступен (нет замеров времени, нет ни оценки ревьюера, ни AI-оценки), он исключается, а итог нормируется на сумму максимумов оставшихся компонентов. Шкала уровней: 80 и выше — «Эксперт», 65–79 — «Сильный специалист», 50–64 — «Уверенный базовый уровень», 35–49 — «Начальный уровень», ниже 35 — «Недостаточно для должности». Алгоритм приведён на рисунке 8.

3 ФУНКЦИОНАЛЬНАЯ МОДЕЛЬ

3.1 Функциональная модель IDEF0

Контекстная диаграмма A-0 показывает систему как один функциональный блок «Проводить оценку и развитие компетенций специалистов ИБ». Входы — данные кандидатов и сотрудников, ответы, сведения о сертификатах; управление — профессиональные стандарты, Положение об ОЦК, законодательство о ПДн, рубрики и методики; выходы — итоговая оценка и отчёт, решение по кандидату, рекомендации по обучению, обезличенная аналитика для ОЦК; механизмы — платформа, ревьюеры и методисты, внешние сервисы проверки сертификатов, языковая модель.

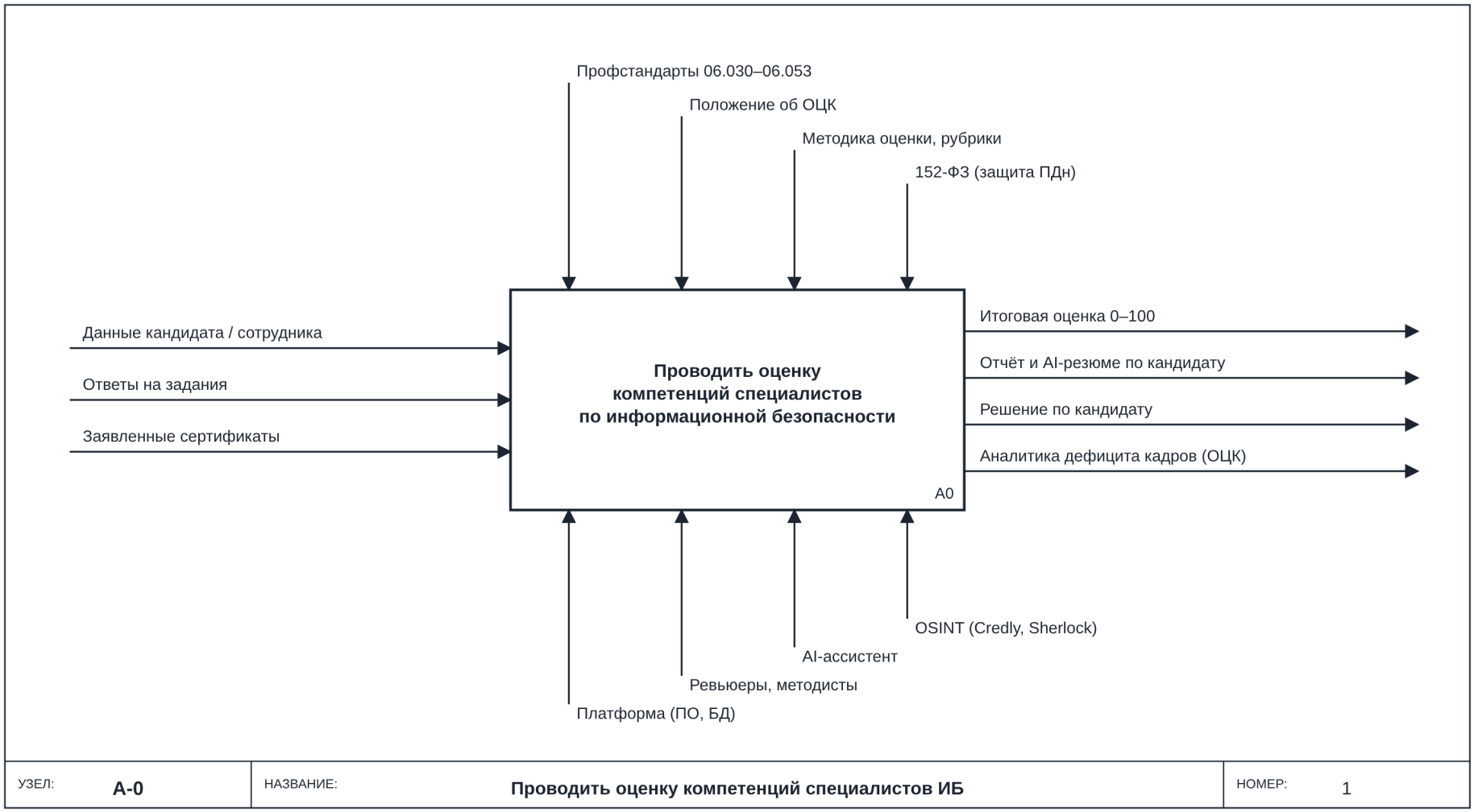


Рисунок 1 — Контекстная диаграмма IDEF0 (A-0)

Декомпозиция A0 выделяет шесть функций: A1 — вести требования и банк задач; A2 — зарегистрировать участника и проверить сертификаты; A3 — провести проверку; A4 — оценить результаты; A5 — сформировать рекомендации и

обучение; A6 — сформировать отраслевую аналитику. Обратная связь A6 → A1 показывает, что выявленные дефициты становятся основанием для новых задач и тем Академии.

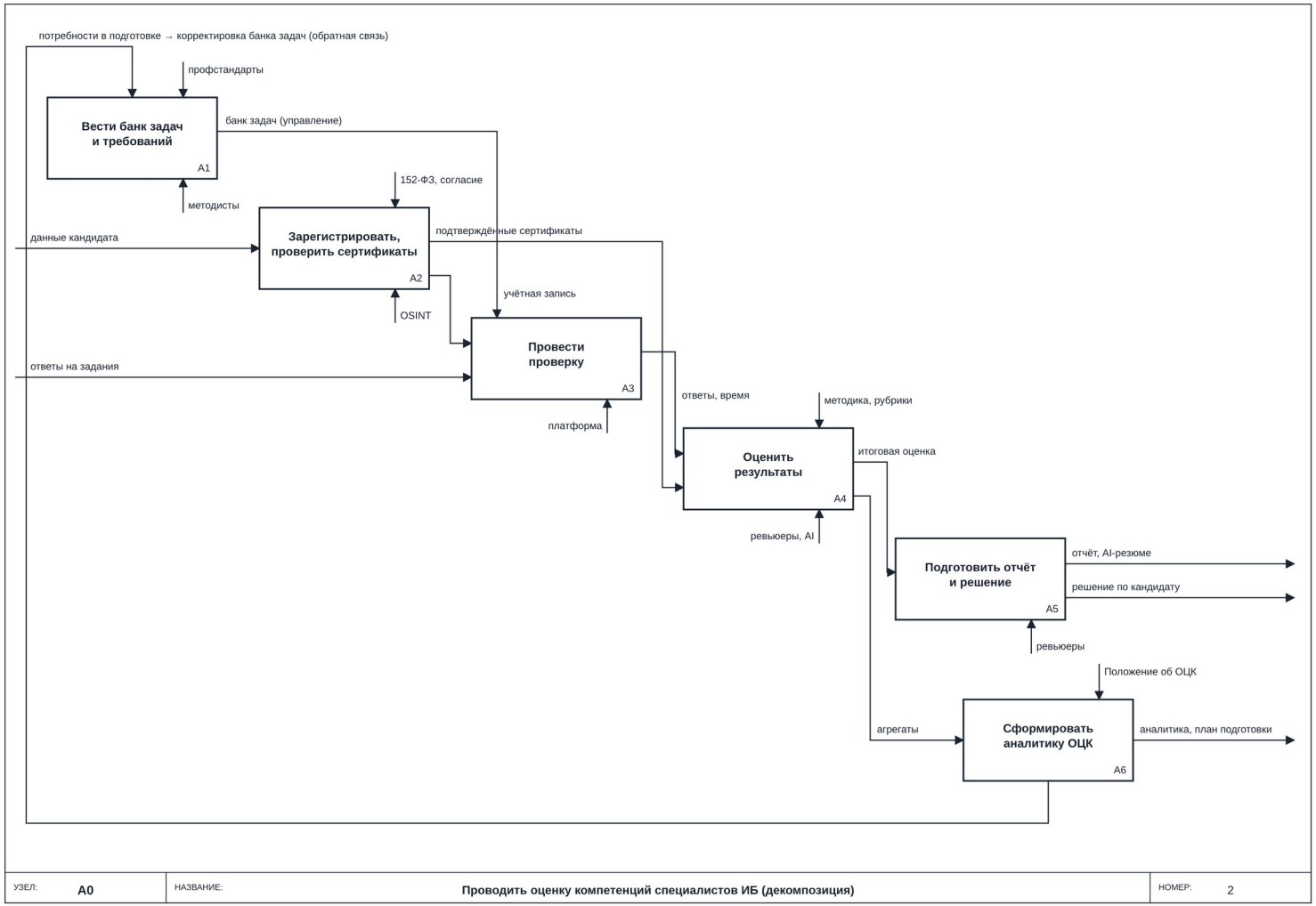


Рисунок 2 — Диаграмма декомпозиции IDEF0 (A0)

3.2 Диаграммы потоков данных

Контекстная DFD фиксирует внешние сущности и границу системы. Диаграмма первого уровня раскрывает пять процессов и четыре хранилища: D1 — требования и задачи, D2 — люди и сертификаты, D3 — проверки и ответы, D4 — оценки и резюме. В аналитику (процесс 5) поступают только агрегаты из D4, а не записи о людях: это и есть граница между контуром компании и контуром ОЦК.



Рисунок 3 — Контекстная диаграмма потоков данных

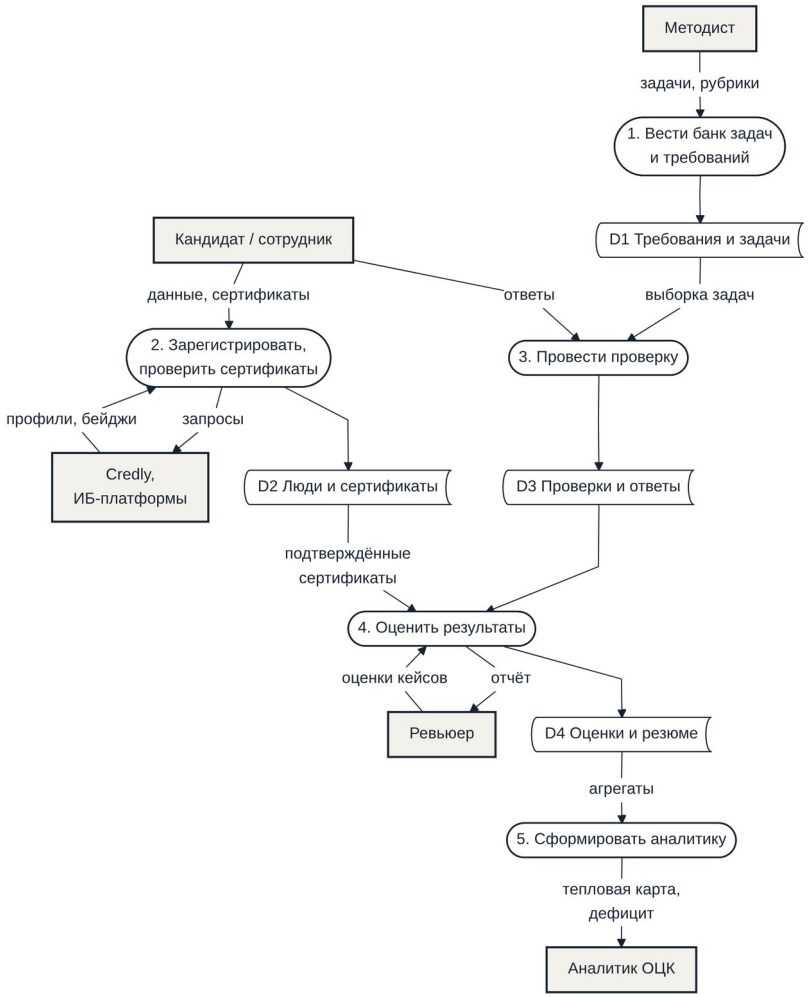


Рисунок 4 — Диаграмма потоков данных первого уровня

3.3 Варианты использования

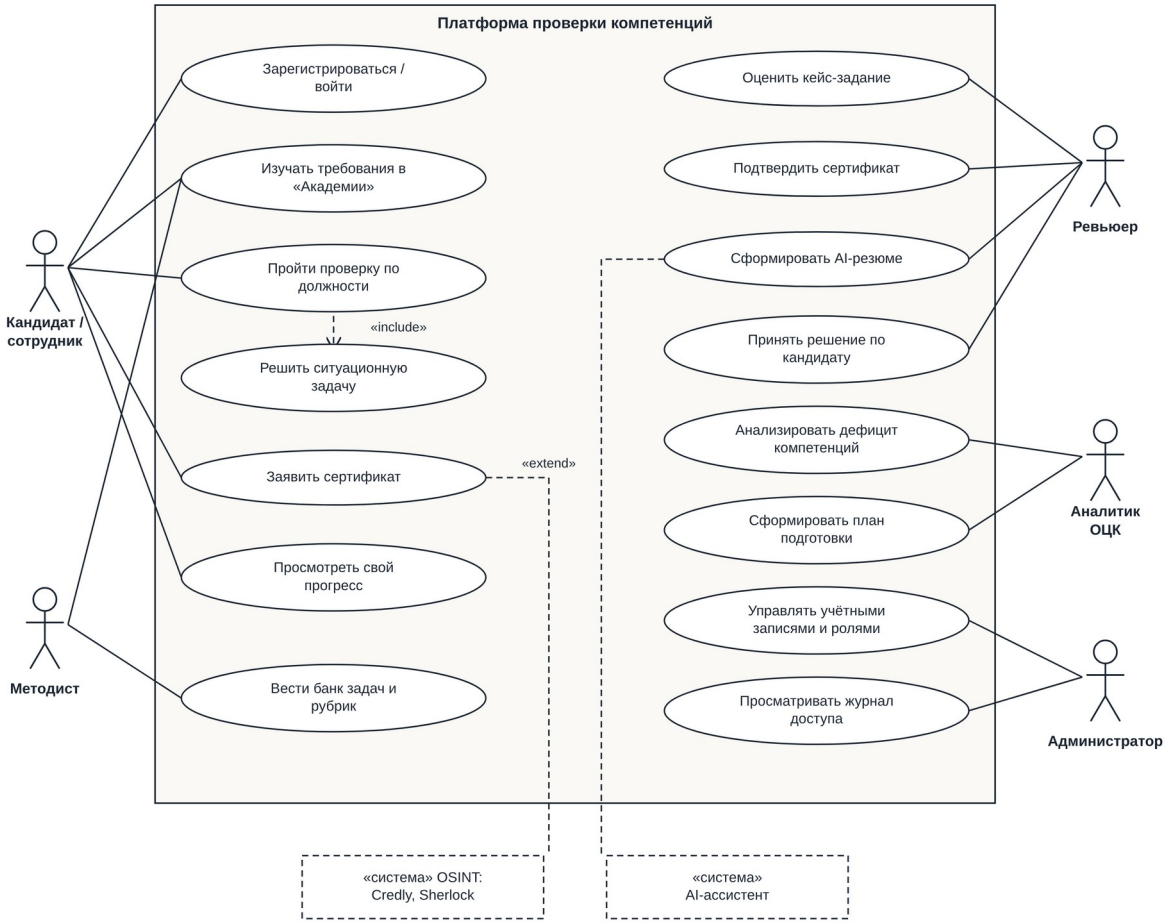


Рисунок 5 — Диаграмма вариантов использования (UML)

Таблица 11 — Основные варианты использования

Код	Вариант использования	Актор	Результат
UC-01	Зарегистрироваться и войти	Кандидат, сотрудник	Учётная запись; выбор роли при нескольких ролях
UC-02	Изучать темы в Академии	Все	Прогресс по темам и задачам
UC-03	Пройти проверку (разминка + задачи)	Кандидат, сотрудник	Отправленная проверка, предварительная оценка
UC-04	Решить ситуационную задачу	Кандидат, сотрудник	Ответы по шагам; при ошибке на критическом шаге — шаг-последствие
UC-05	Проверить сертификаты (OSINT) «extend» UC-01	Система	Найденные профили и бейджи на подтверждение
UC-06	Оценить развёрнутый ответ по рубрике	Ревьюер	Балл и комментарий; пересчёт итоговой оценки
UC-07	Получить AI-резюме	Ревьюер, AI-ассистент	Сильные и слабые стороны, рекомендации
UC-08	Принять решение по кандидату	Ревьюер	Решение и PDF-отчёт
UC-09	Создать или изменить задачу и рубрику	Методист	Опубликованная задача, привязанная к ТФ и темам
UC-10	Смотреть тепловую карту дефицита	Аналитик ОЦК	Срез по организациям и направлениям ОЦК
UC-11	Сформировать план подготовки кадров	Аналитик ОЦК	Выгрузка «направление — количество — срок»
UC-12	Управлять пользователями и ролями	Администратор	Назначенные роли, журнал доступа

4 СХЕМЫ АЛГОРИТМОВ (ГОСТ 19.701-90)

Схемы выполнены по ГОСТ 19.701-90 «Схемы алгоритмов, программ, данных и систем». Направление потока — сверху вниз; стрелки ставятся только там, где поток отклоняется от основного направления или возвращается назад (циклы).

Таблица 12 — Использованные символы ГОСТ 19.701-90

Символ	**Назначение в схемах**
Терминатор	Начало и конец алгоритма
Процесс	Действие системы или пользователя
Решение	Ветвление по условию (выходы «да» / «нет»)
Данные	Ввод или вывод данных без уточнения носителя
Предопределённый процесс	Вызов алгоритма, описанного на отдельном рисунке
Документ	Формируемый документ (отчёт, PDF)
Граница цикла	Начало и конец цикла (пара символов)
Ручной ввод	Ввод данных пользователем с клавиатуры
Запоминаемые данные	Хранение в базе данных

4.1 Алгоритм прохождения проверки

Верхнеуровневый алгоритм (рис. 6) объединяет вход, проверку сертификатов, разминку, цикл по ситуационным задачам и формирование предварительной оценки. Прохождение можно прервать и продолжить: состояние сохраняется после каждого ответа.

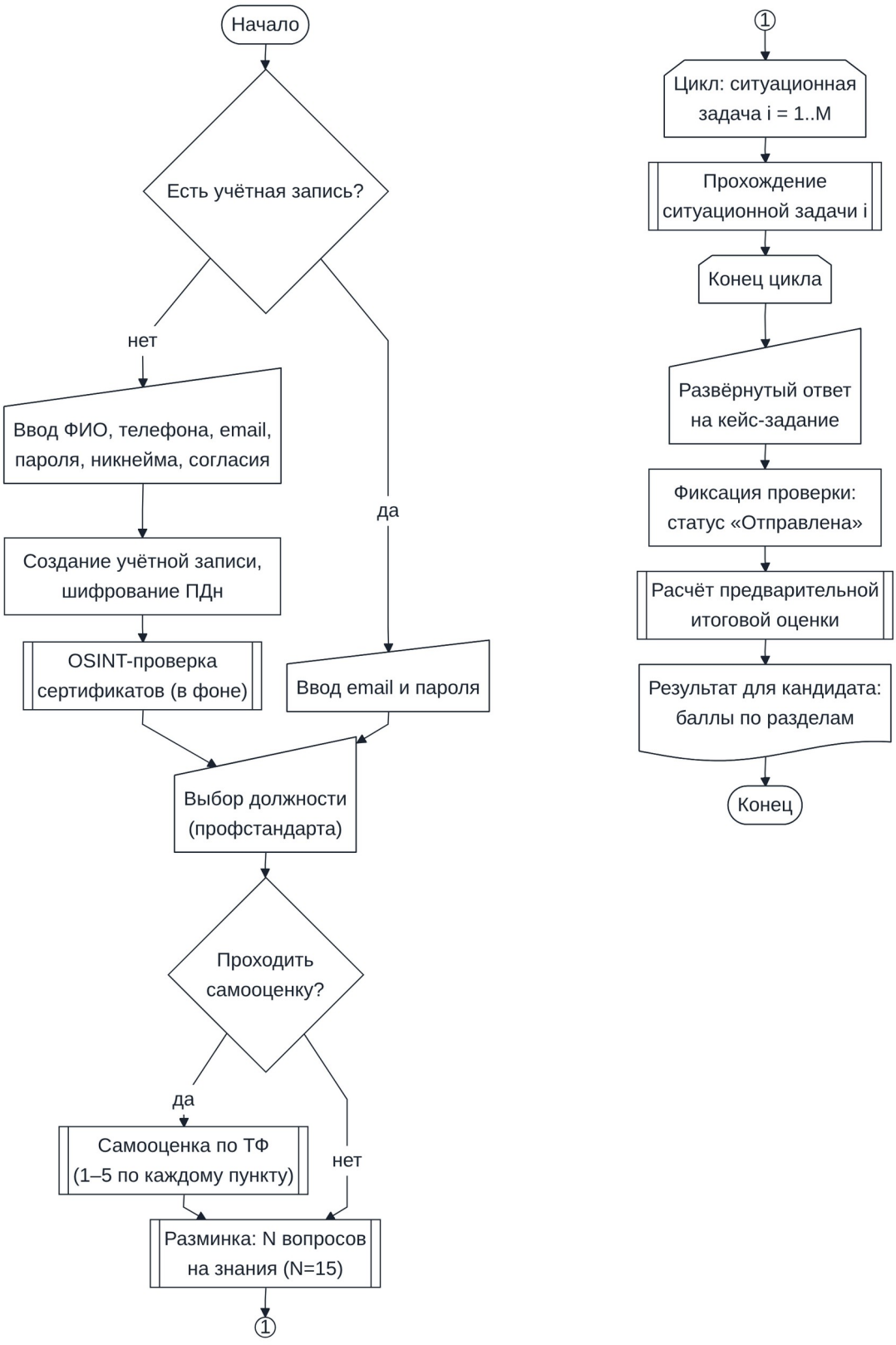


Рисунок 6 — Схема алгоритма прохождения проверки

4.2 Алгоритм ситуационной задачи

Задача выполняется пошагово (рис. 7). После каждого ответа шаг проверяется автоматически или помечается для ревьюера. Ошибка на

критическом шаге вставляет шаг-последствие. Ответы и время сохраняются сразу, поэтому сбой связи не приводит к потере работы.

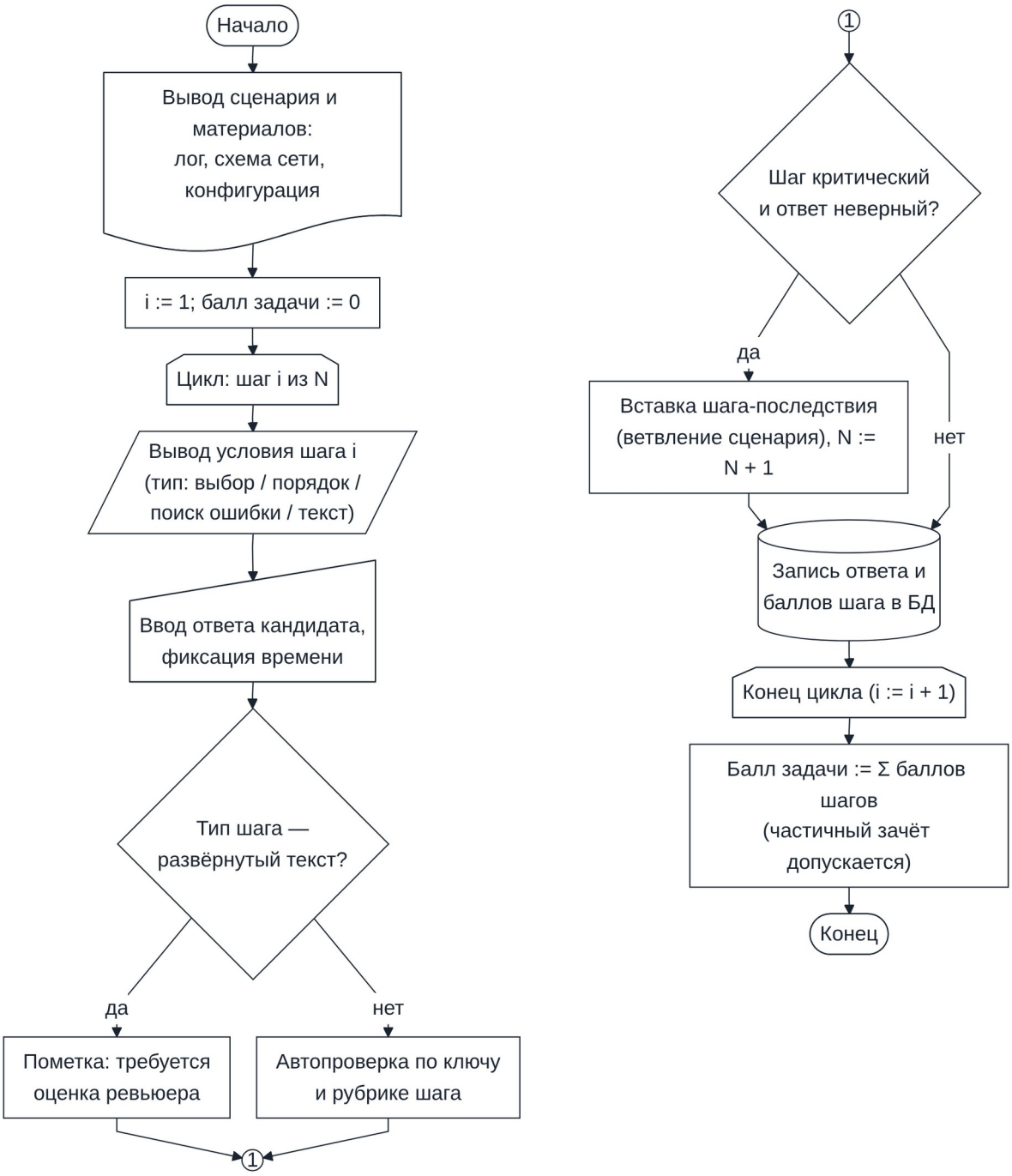


Рисунок 7 — Схема алгоритма выполнения ситуационной задачи

4.3 Алгоритм расчёта итоговой оценки

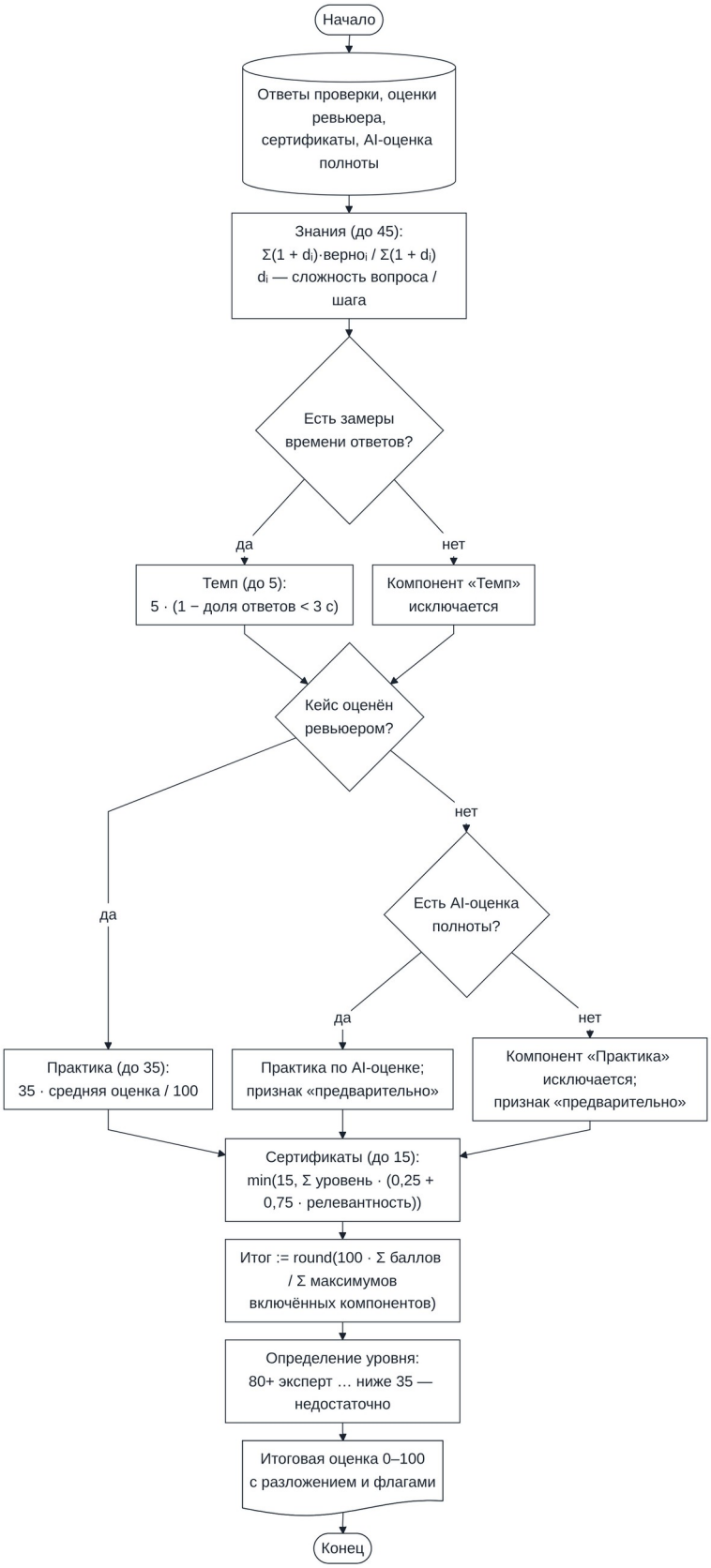


Рисунок 8 — Схема алгоритма расчёта итоговой оценки

4.4 Алгоритм проверки сертификатов по открытым источникам

Поиск выполняется по ФИО (с транслитерацией) и e-mail. Бейджи Credly, найденные по угаданному имени профиля, засчитываются только при совпадении хеша e-mail в утверждении Open Badges: это исключает ошибочное приписывание сертификатов однофамильцу. Все находки получают статус «на проверке» и становятся подтверждёнными только после решения ревьюера.

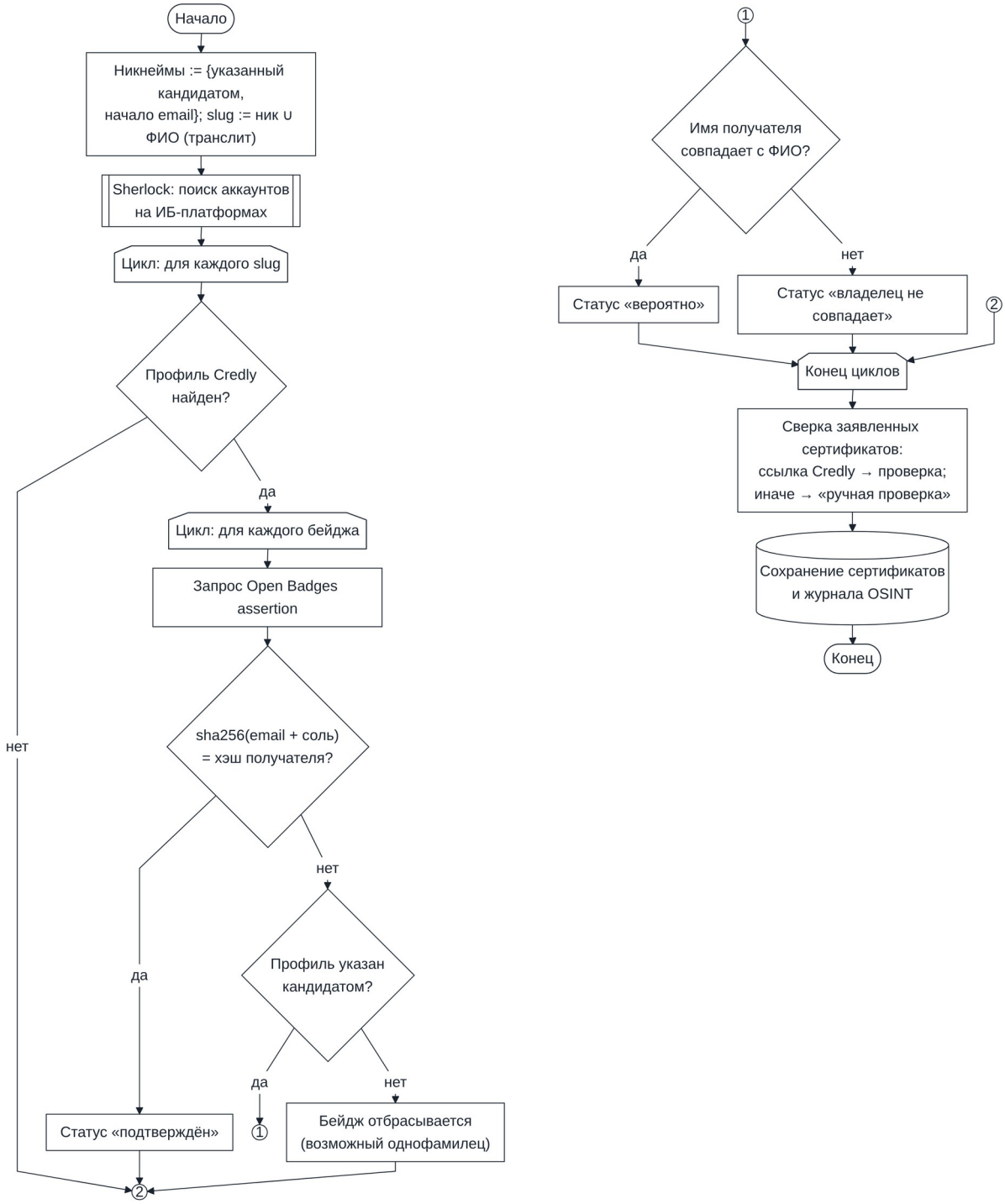


Рисунок 9 — Схема алгоритма проверки сертификатов

4.5 Алгоритм оценки ревьюером

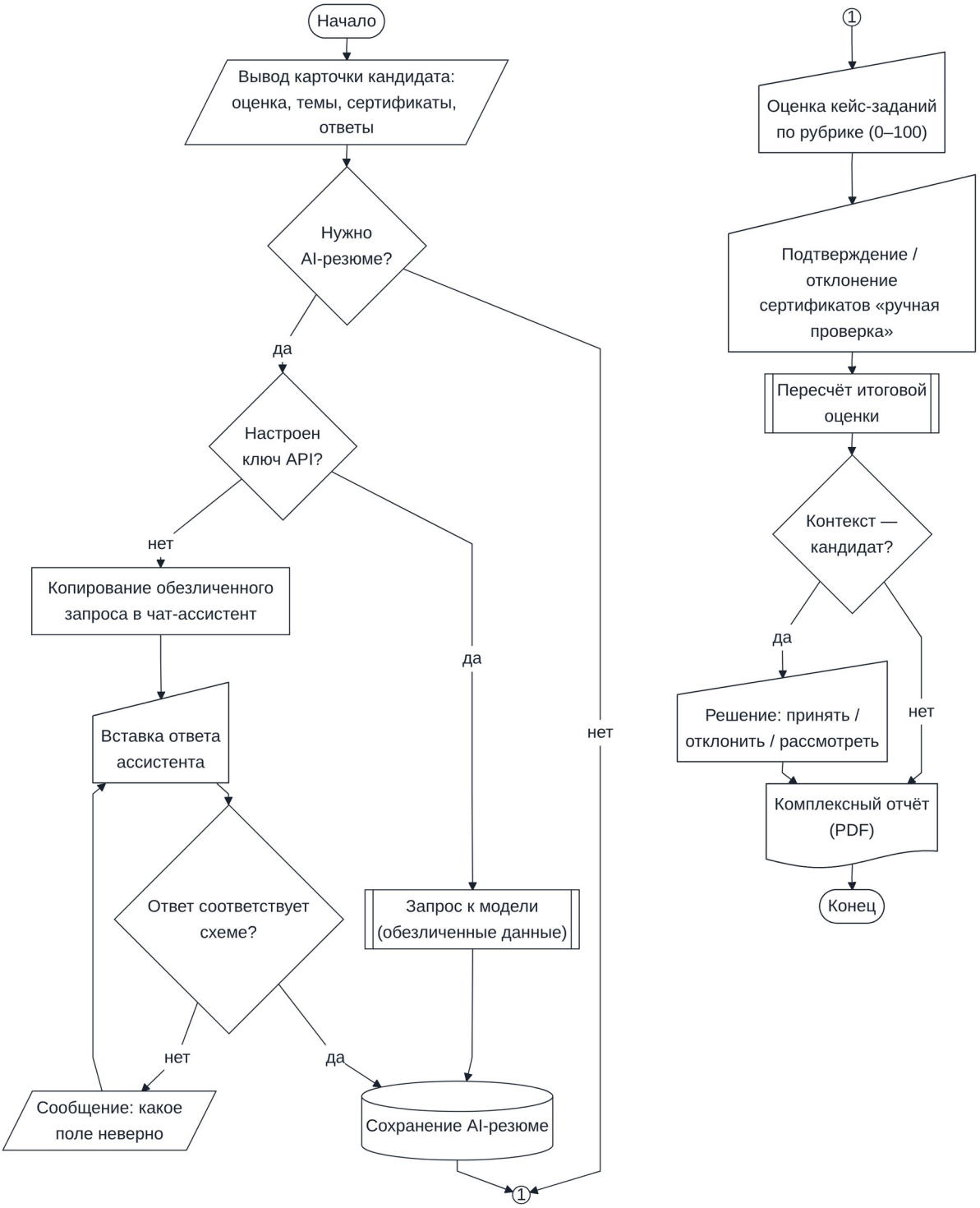


Рисунок 10 — Схема алгоритма работы ревьюера

4.6 Алгоритм входа и выбора роли

После проверки пароля определяется набор ролей пользователя. При одной роли открывается её стартовый раздел, при нескольких — экран выбора. Меню строится по выбранной роли, а бейдж роли выводится в шапке. После пяти неудачных попыток вход временно блокируется.

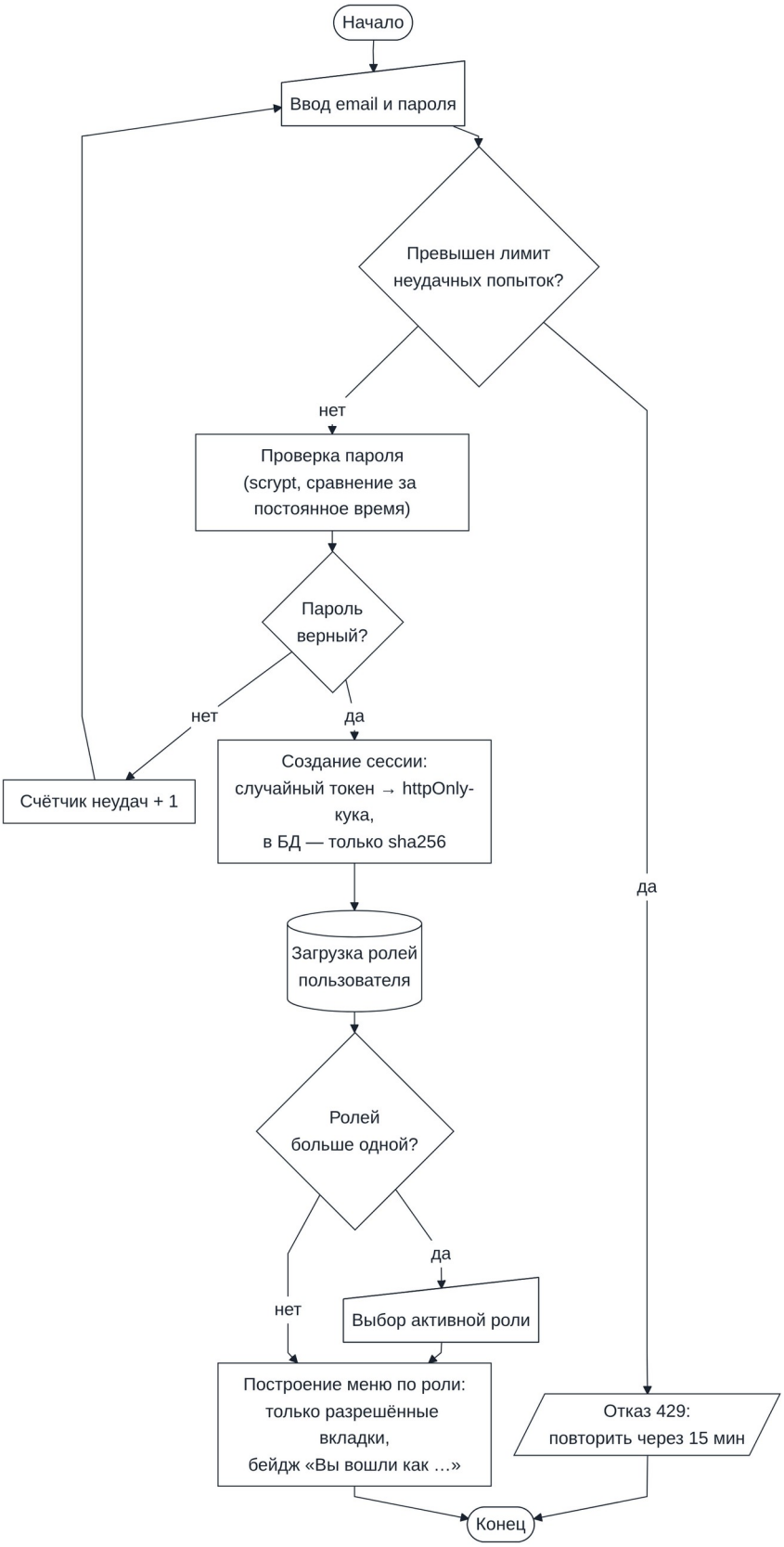


Рисунок 11 — Схема алгоритма входа и выбора роли

5 ПОВЕДЕНЧЕСКИЕ МОДЕЛИ (UML)

5.1 Диаграммы последовательности

Регистрация (рис. 12): персональные данные шифруются до записи в БД, поиск сертификатов запускается асинхронно и не задерживает пользователя.

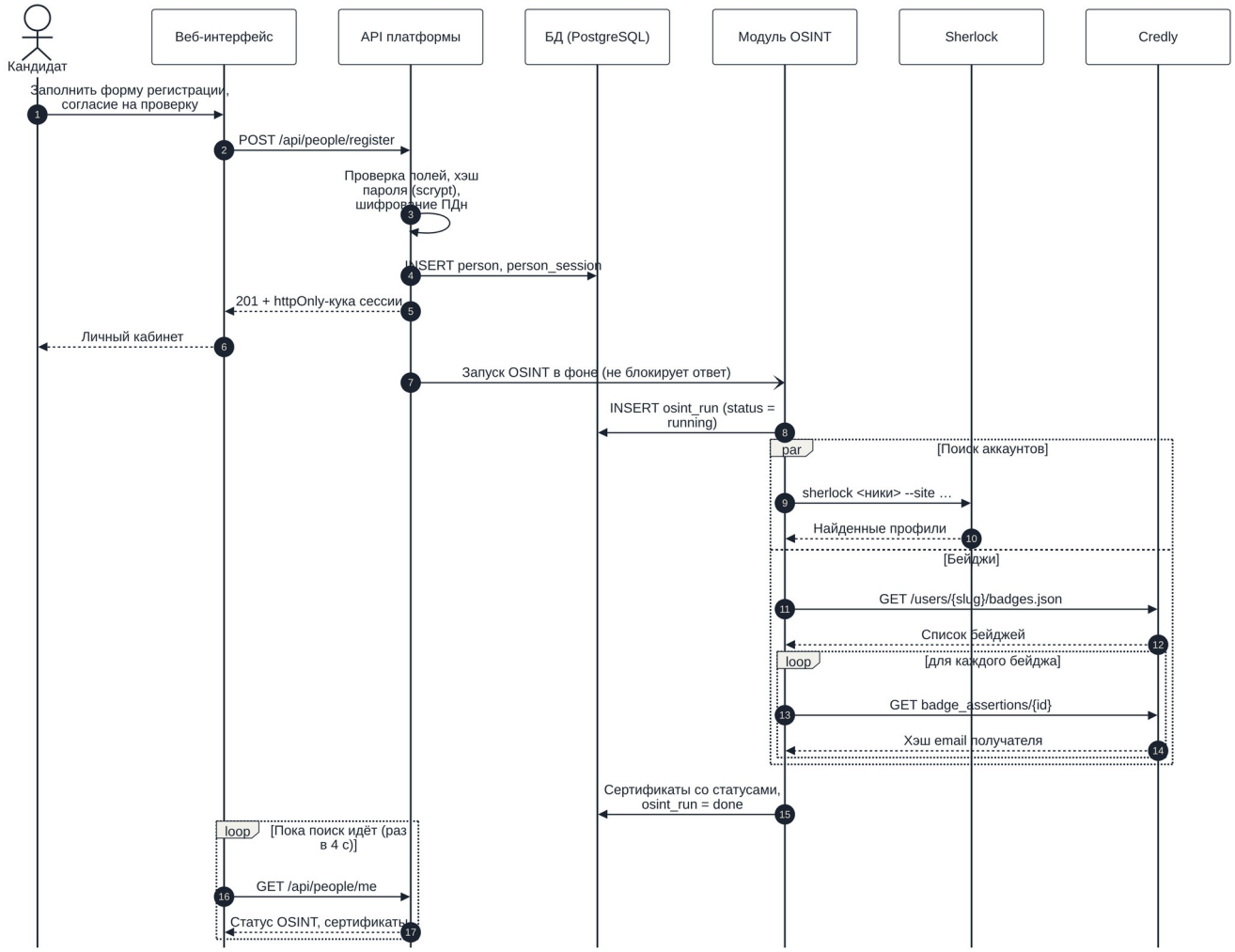


Рисунок 12 — Последовательность: регистрация и проверка сертификатов

Шаг ситуационной задачи (рис. 13): клиент запрашивает текущий шаг, сервер выдаёт его без правильного ответа; проверка выполняется на сервере, а при ошибке на критическом шаге сервер возвращает шаг-последствие.

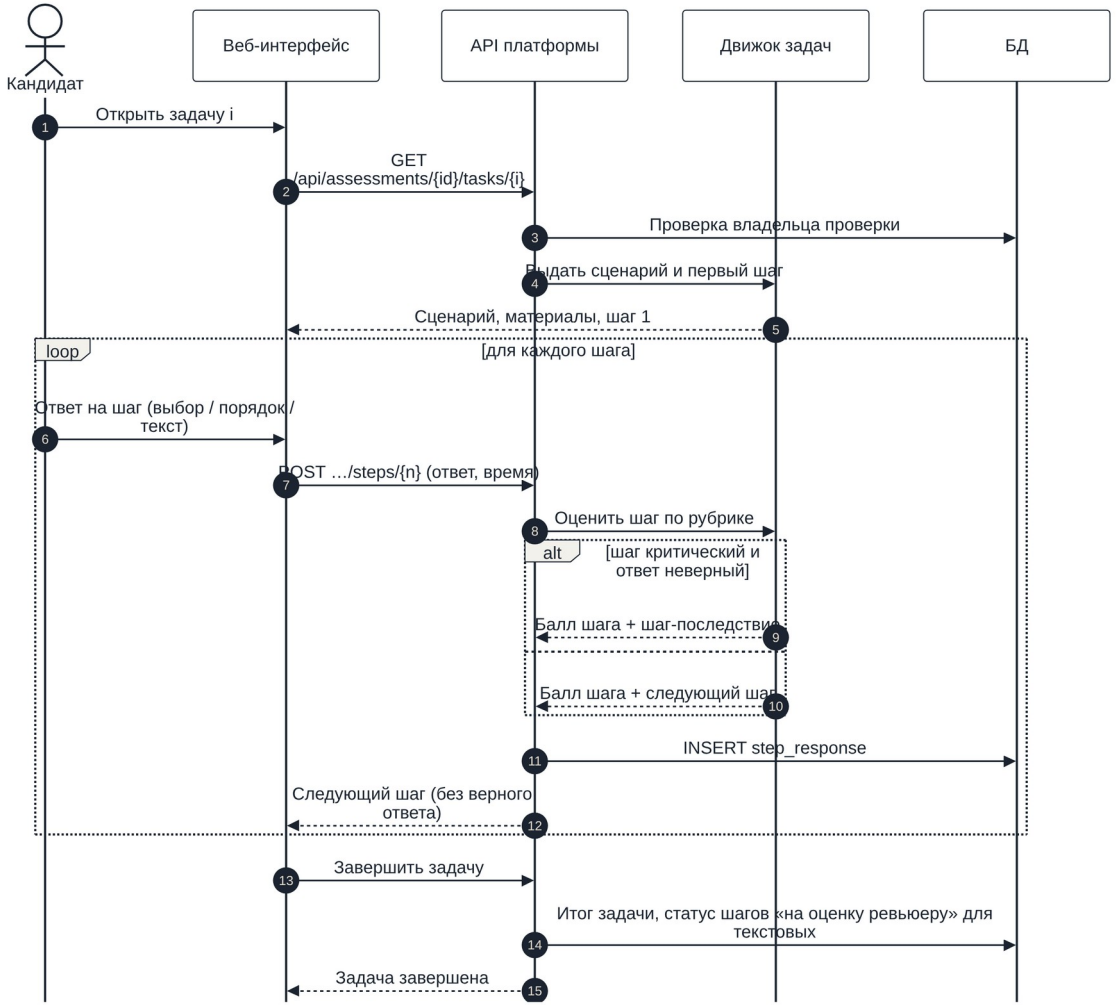


Рисунок 13 — Последовательность: выполнение шага ситуационной задачи

AI-резюме в ручном режиме (рис. 14): платформа формирует запрос без ФИО и контактов, ревьюер вставляет его во внешний чат-ассистент и возвращает ответ; ответ проверяется по схеме и сохраняется только при успешной проверке.

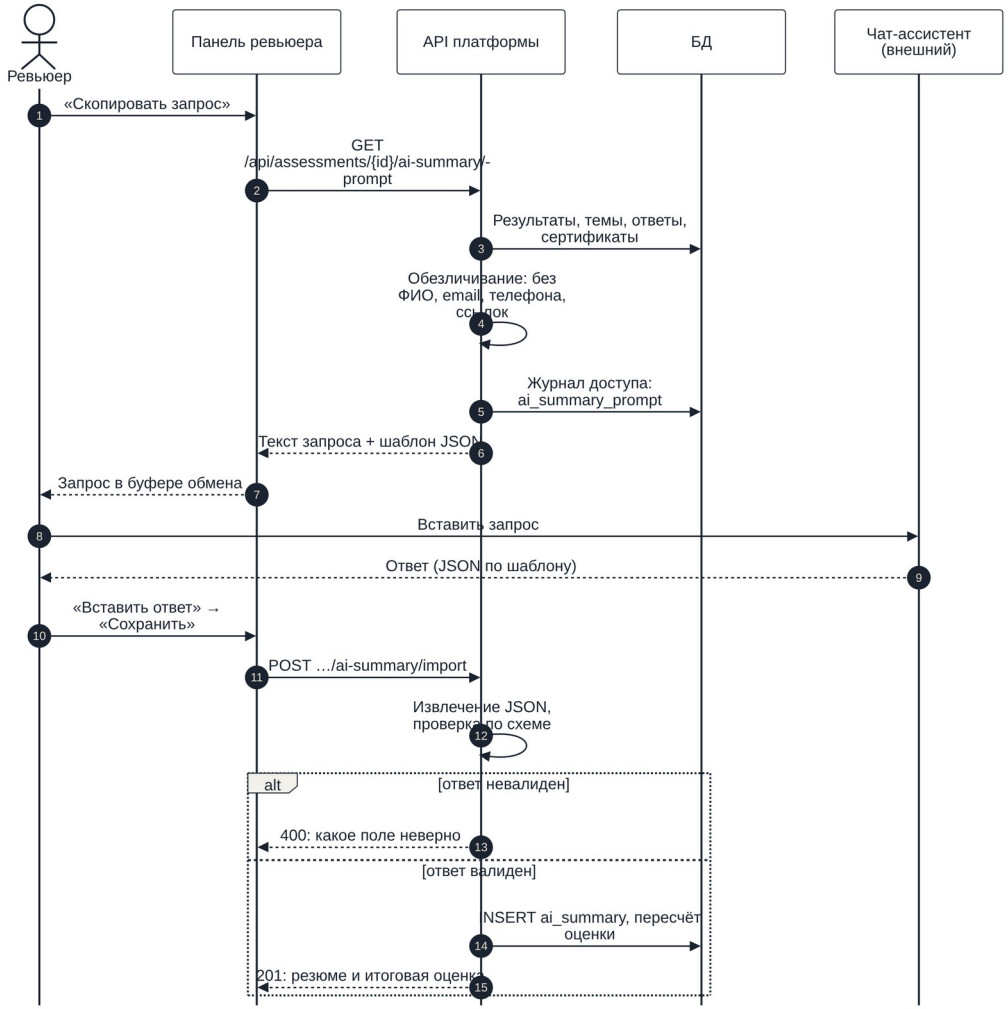


Рисунок 14 — Последовательность: AI-резюме в ручном режиме

5.2 Диаграммы состояний

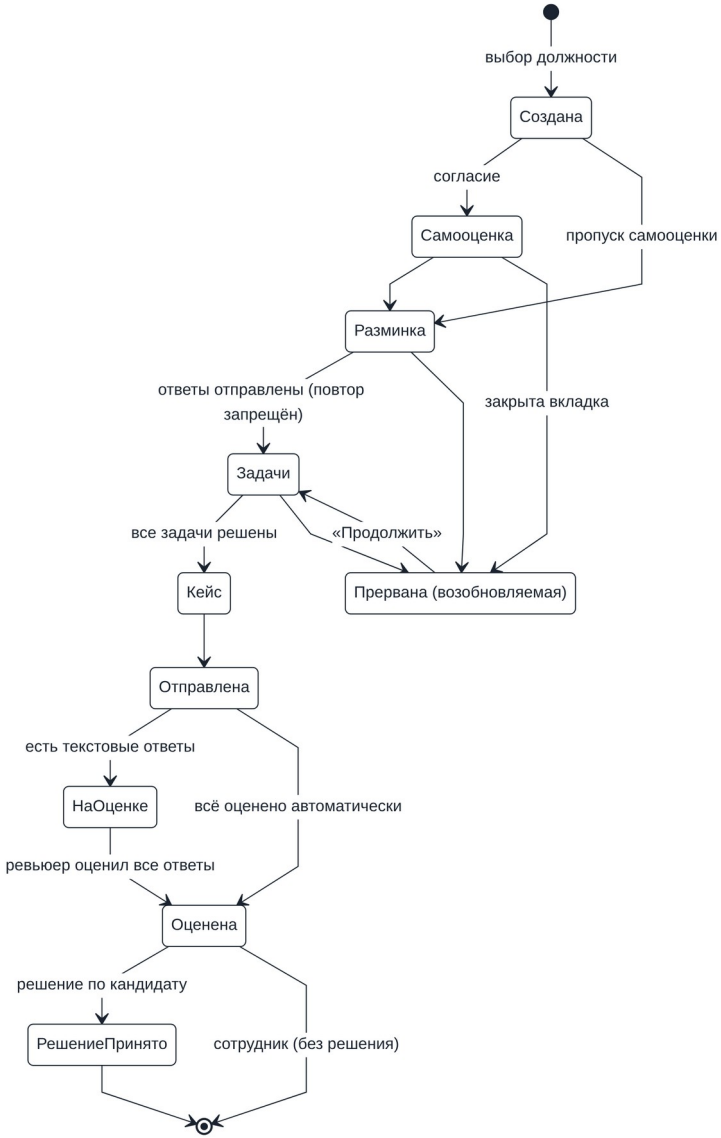


Рисунок 15 — Состояния проверки

Проверка проходит состояния: создана → самооценка/разминка → задачи → кейс → отправлена → на оценке → оценена → решение принято. Из состояний прохождения возможен переход «прервана», из которого проверку можно продолжить.

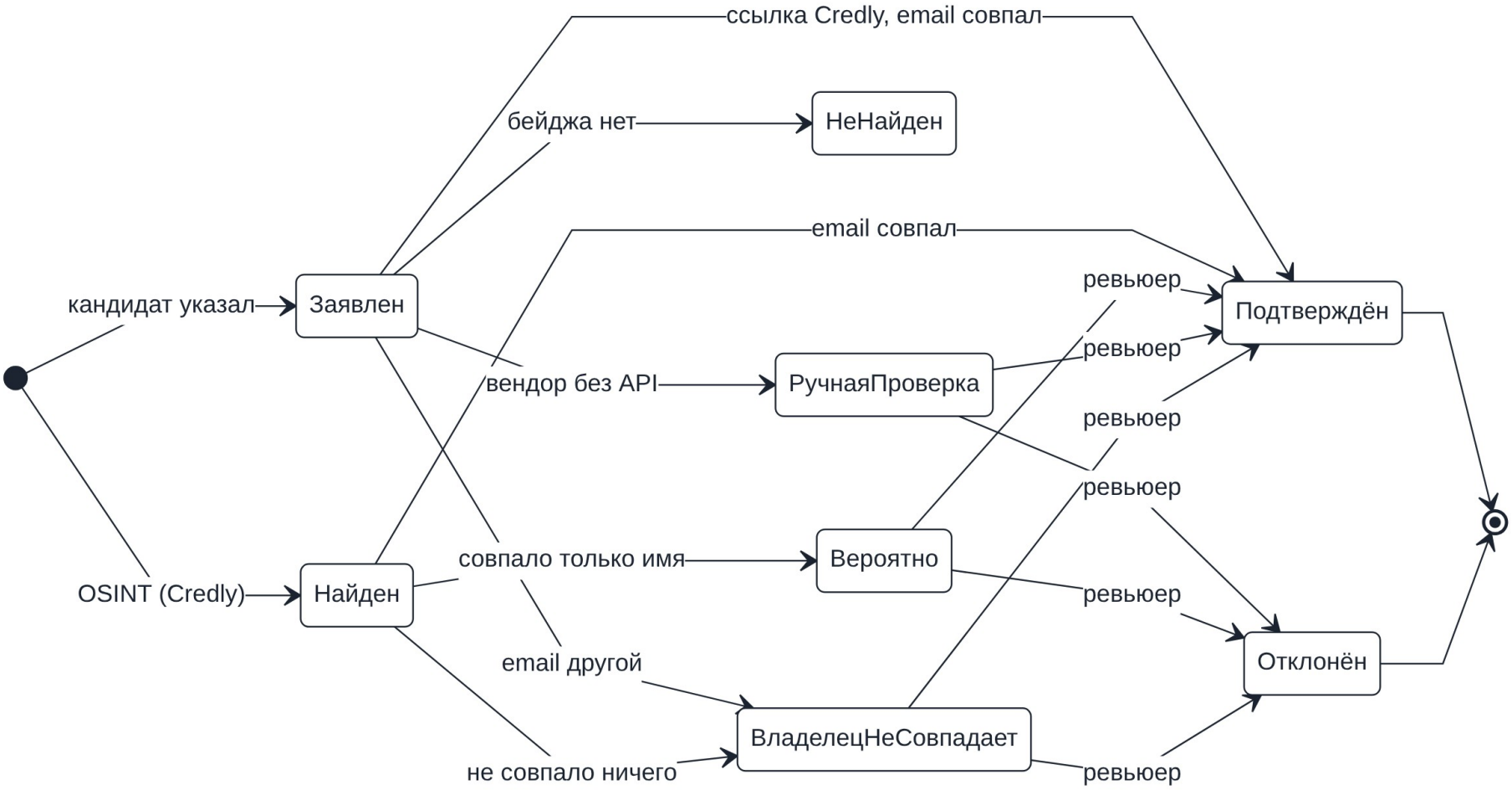


Рисунок 16 — Состояния сертификата

Сертификат, найденный автоматически или добавленный кандидатом, находится в состоянии «на проверке» до решения ревьюера. В итоговую оценку входят только подтверждённые сертификаты; у сертификатов с ограниченным сроком действия предусмотрено состояние «истёк».

6 МОДЕЛЬ ДАННЫХ

Модель разделена на две части: методическое содержание (стандарты, темы, задачи, рубрики) и данные о людях и проверках. Диаграммы показывают сущности и связи, атрибуты приведены в словаре данных (таблицы 13 и 14). Поля, отмеченные знаком «(шифр.)», хранятся в зашифрованном виде (AES-256-GCM); для поиска по e-mail хранится его хеш.

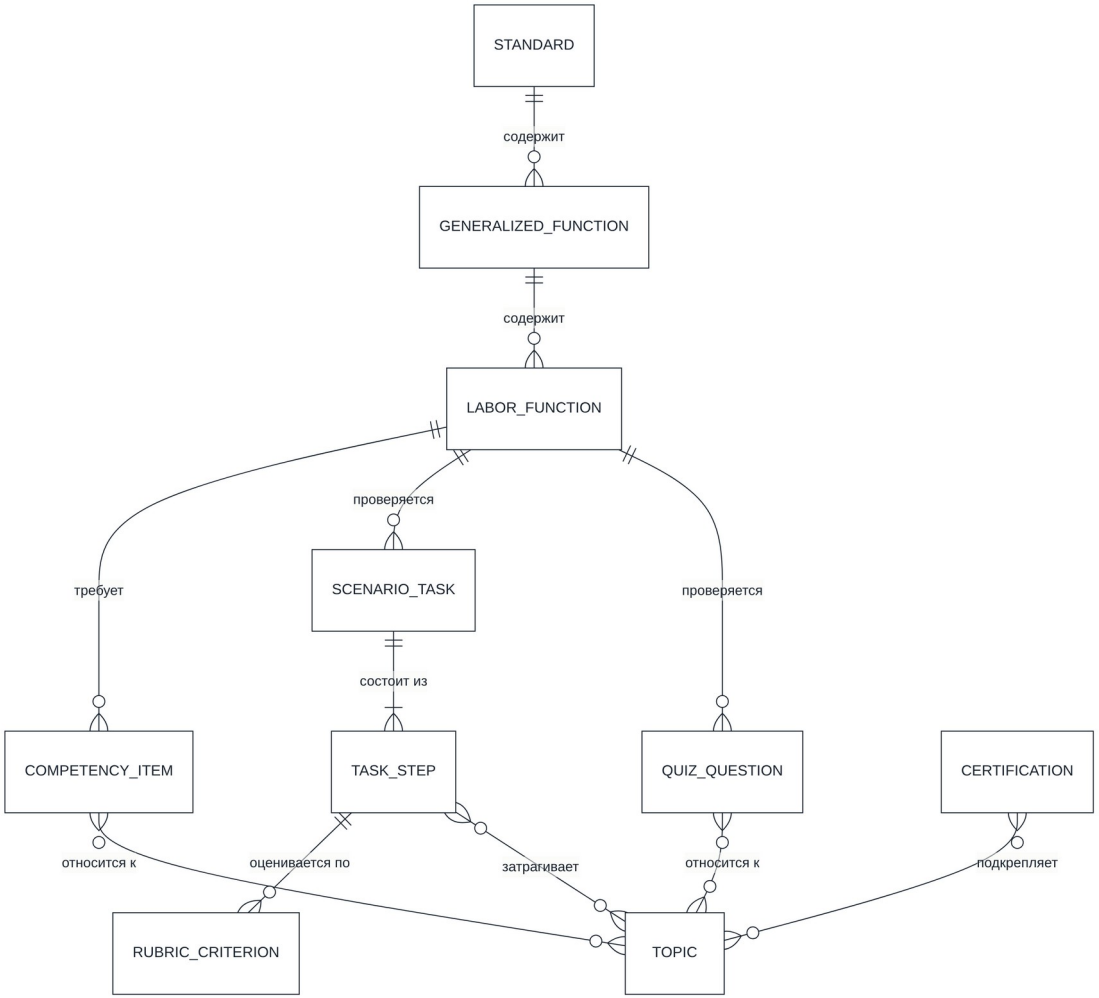


Рисунок 17 — ER-диаграмма: методическое содержание

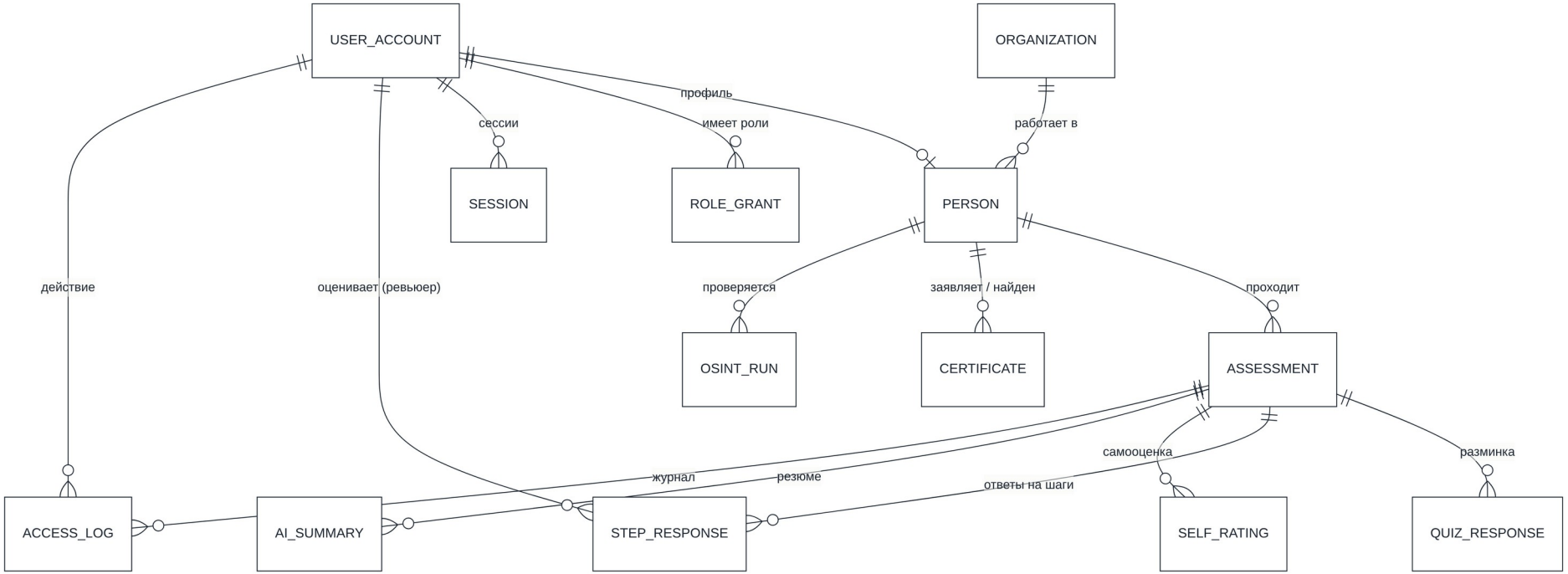


Рисунок 18 — ER-диаграмма: люди, проверки и оценки

Таблица 13 — Словарь данных: методическое содержание

Сущность	Ключевые атрибуты	Назначение
STANDARD	code, title, order_ref	Профессиональный стандарт
GENERALIZED_FUNCTION	code, title, level	Обобщённая трудовая функция
LABOR_FUNCTION	code, title, level	Трудовая функция (например, A/01.5)
COMPETENCY_ITEM	kind (знание / умение / действие), text	Элемент ТФ
TOPIC	slug, title, category, rules (regex)	Тема Академии; правила сопоставления с элементами ТФ
OCK_DIRECTION	code (4.3.1.x), title	Направление деятельности ОЦК
SCENARIO_TASK	title, scenario, materials (jsonb), level, status, version	Ситуационная задача
TASK_STEP	order*no, step*type, payload (jsonb), critical, consequences*step*id	Шаг задачи; ссылка на шаг-последствие
RUBRIC_CRITERION	step*id, criterion, max*points	Критерий рубрики текстового шага
QUIZ_QUESTION	text, options, correct*index, labor*function_id	Вопрос разминки
CERTIFICATION	vendor, name, level, topics, verify_method	Каталог известных сертификатов

Таблица 14 — Словарь данных: люди, проверки и оценки

Сущность	Ключевые атрибуты	Назначение
ORGANIZATION	name, industry, inn_hash	Организация (контур компании)
USER_ACCOUNT	email*hash, email (шифр.), password*hash (scrypt), locked_until	Учётная запись
ROLE_GRANT	user*id, role, organization*id	Назначенная роль в организации
SESSION	token*hash, role, expires*at	Сессия с выбранной ролью
PERSON	full_name (шифр.), phone (шифр.), context (кандидат / сотрудник)	Проверяемый человек
ASSESSMENT	status, standard*id, task*assignment, quiz*submitted*at, decision	Проверка
QUIZ_RESPONSE	question*id, chosen*index, correct, time_ms	Ответ разминки
STEP_RESPONSE	step*id, answer (jsonb), time*ms, auto*points, reviewer*points, ai_points	Ответ на шаг задачи

Сущность	Ключевые атрибуты	Назначение
SELF_RATING	topic_id, rating	Самооценка по теме
CERTIFICATE	source, vendor, name, status, reviewed*by*, *expires*at	Сертификат человека
OSINT_RUN	status, profiles (jsonb), credly (jsonb)	Запуск поиска по открытым источникам
AI_SUMMARY	model, source (api / manual), content (jsonb)	AI-резюме
ACCESS_LOG	user_id, action, object, at	Журнал доступа к ПДн
ANALYTICS_AGGREGATE	organization*id*, *direction*id, level, period, n, share_below	Обезличенный агрегат для ОЦК (n ≥ 5)

7 АРХИТЕКТУРА И БЕЗОПАСНОСТЬ

7.1 Компоненты

Система построена как модульный монолит: один серверный процесс с чётко разделёнными модулями. Для ожидаемой нагрузки (сотни проверок в месяц на организацию) это проще в эксплуатации, чем микросервисы, а границы модулей позволят выделить, например, OSINT в отдельный сервис, если это потребуется.

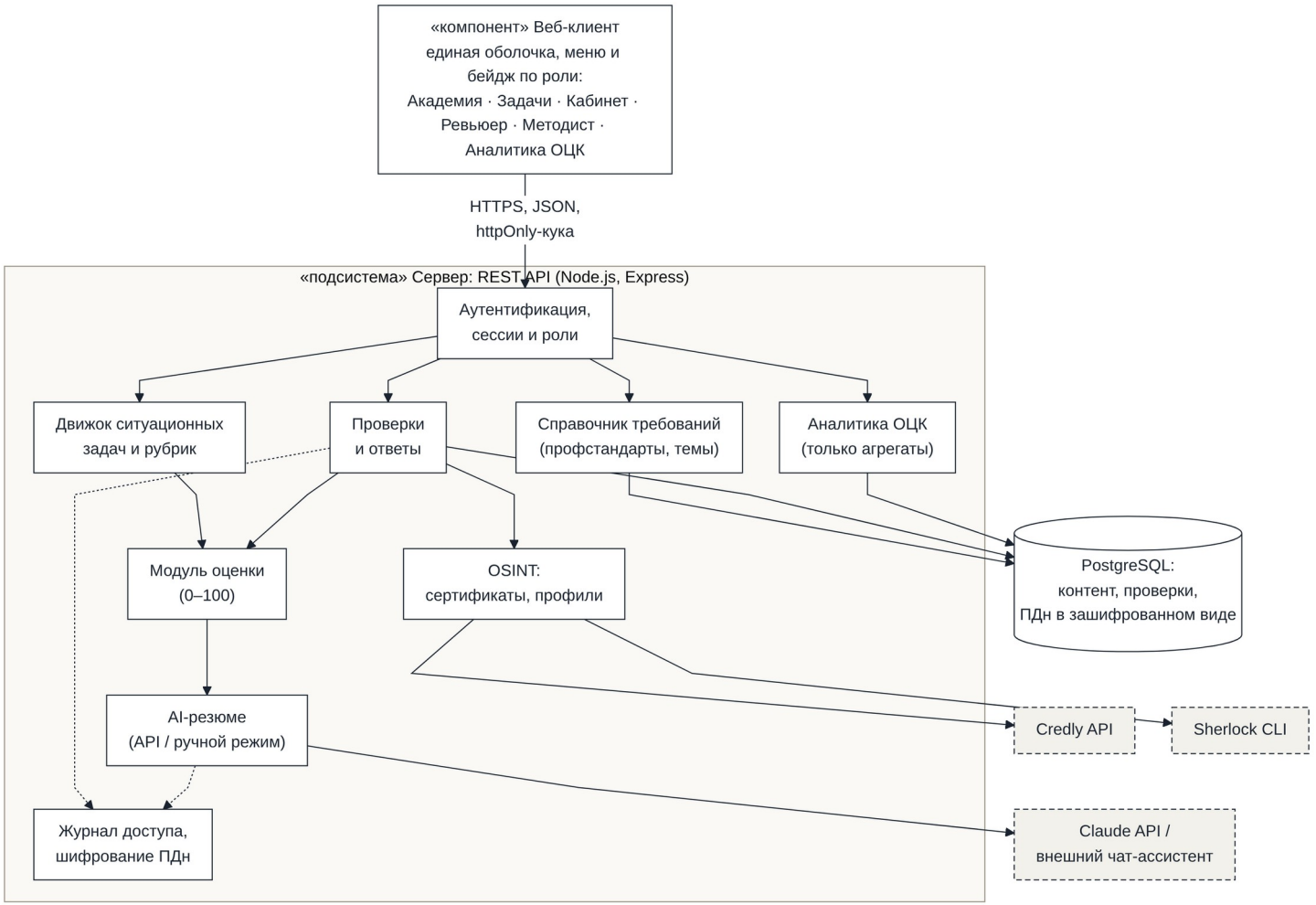


Рисунок 19 — Диаграмма компонентов

Таблица 15 — Модули сервера

Модуль	**Ответственность**
Аутентификация и роли	Вход, сессии, выбор роли, блокировка после неудачных попыток, проверка прав на каждом запросе
Требования и Академия	Стандарты, ТФ, темы, правила сопоставления, направления ОЦК, прогресс
Движок задач	Выдача шагов без правильных ответов, проверка ответа, вставка шагов-последствий
Проверки	Жизненный цикл проверки, подбор задач, сохранение ответов
Оценка	Итоговая оценка с разложением, калибровка сложности
OSINT	Sherlock, Credly, сопоставление имён, очередь подтверждения
AI-резюме	Запрос к API или ручной режим, проверка ответа по схеме
Аналитика ОЦК	Расчёт агрегатов с порогом минимальной группы, выгрузка плана подготовки
Аудит и ПДн	Шифрование полей, журнал доступа, сроки хранения

7.2 Развёртывание

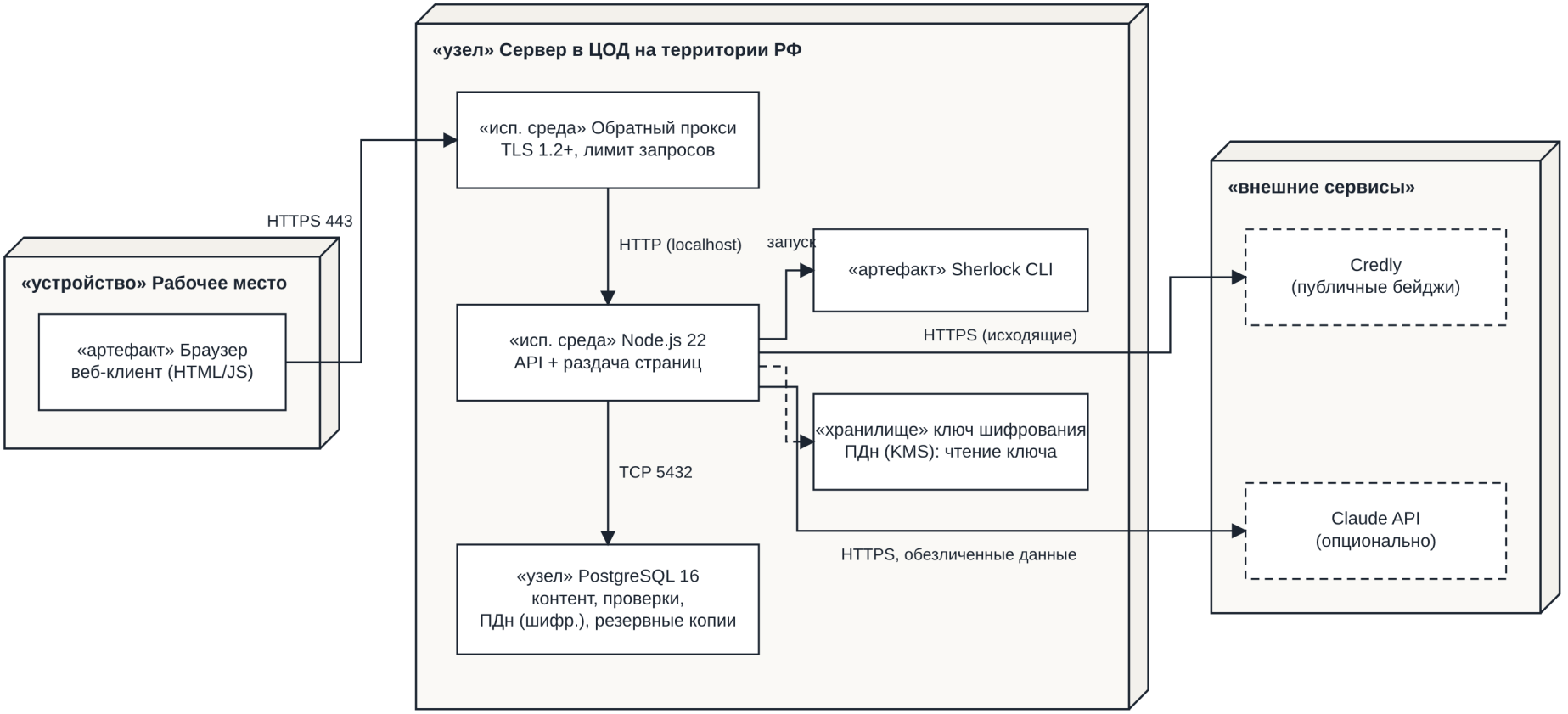


Рисунок 20 — Диаграмма развёртывания

Таблица 16 — Технологический стек

Слой	Технология	Обоснование
Клиент	HTML, CSS, JavaScript без фреймворка; единая оболочка	Простые страницы, быстрая загрузка, нет сборки
Сервер	Node.js 22, Express 5	Уже используется в прототипе
База данных	PostgreSQL 16 (jsonb для материалов и ответов)	Транзакции, гибкие структуры шагов
OSINT	Sherlock (CLI), Credly (публичный API бейджей)	Открытые источники, без платных подписок
AI	Claude API или ручной режим через внешний ассистент	Работа без ключа API возможна
Шифрование	AES-256-GCM для ПДн, scrypt для паролей, ключ в KMS	Защита ПДн при утечке БД
Тесты и CI	node --test (интеграционные), GitHub Actions	Проверка каждого изменения

7.3 Безопасность и персональные данные

- **Минимизация.** Собираются только ФИО, телефон и e-mail; телефон и e-mail зашифрованы, поиск — по хешу.
- **Разделение ролей.** Права проверяются на сервере на каждом запросе; скрытие вкладки в меню — удобство, а не защита.
- **Журнал доступа.** Каждое открытие карточки кандидата с ПДн записывается в ACCESS_LOG.
- **Обезличивание для ОЦК.** Агрегаты считаются в контуре компании; группы меньше 5 человек не передаются.
- **AI без ПДн.** В запрос к языковой модели не включаются ФИО и контакты, только ответы и результаты.
- **Защита задач.** Правильные ответы не передаются клиенту до завершения задачи; проверка выполняется на сервере.
- **Сессии.** Cookie с флагами httpOnly, Secure, SameSite; ограничение попыток входа.

На этапе PoC требования законодательства о ПДн учитываются как ориентир архитектуры; полное соответствие (модель угроз, оценка вреда, локализация) прорабатывается перед пилотом в реальной организации.

7.4 Программный интерфейс (эскиз)

Таблица 17 — Основные группы методов API

Группа	Примеры методов	Доступ
auth	POST /auth/login, POST /auth/role, POST /auth/logout	Все
academy	GET /academy/standards, GET /academy/topics/:slug	Все
tasks	GET /tasks?topic=&level=&standard=&direction=	Все
assessments	POST /assessments, GET /assessments/:id/next-step, POST /assessments/:id/steps/:stepId	Кандидат, сотрудник
review	GET /review/queue, PUT /review/steps/:id, POST /review/assessments/:id/decision	Ревьюер
methodist	POST /tasks, PUT /tasks/:id, POST /tasks/:id/publish	Методист
analytics	GET /analytics/heatmap, GET /analytics/training-plan.csv	Аналитик ОЦК
admin	GET /admin/users, PUT /admin/users/:id/roles, GET /admin/access-log	Администратор

8 ИНТЕРФЕЙС

8.1 Принципы единой оболочки

- **Одна шапка на всех экранах:** логотип, вкладки разделов, бейдж роли «Вы вошли как: <роль> ▾» с переключением роли, меню профиля.
- **Вкладки по роли:** Академия и Задачи есть у всех; Кабинет и Мои проверки — у кандидата и сотрудника; Ревьюер, Методист, Аналитика ОЦК, Администрирование — только у соответствующей роли.
- **Боковая навигация раздела** слева и контекстная панель справа (прогресс, рекомендации, рубрика).
- **Единая система уровней:** метки БАЗОВЫЙ / СПЕЦИАЛИСТ / ЭКСПЕРТ и статусы «решено / не решено» одинаковы во всех разделах.
- **Не больше двух кликов** от любой темы до задачи по ней и от любой задачи до требований, которые она проверяет.

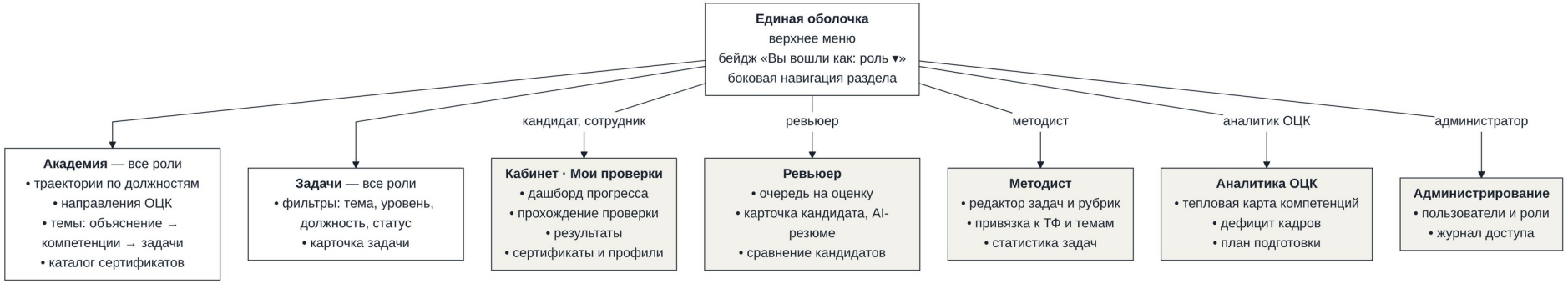


Рисунок 21 — Карта разделов по ролям

8.2 Макеты экранов

Ниже приведены низкодетализированные макеты (wireframes). Они фиксируют состав и расположение элементов, а не визуальный стиль; жёлтые выноски с номерами поясняют ключевые решения.

Академия: страница темы. Слева — траектории по должностям и темы выбранной траектории; в центре — объяснение темы, перечень ТФ, где она требуется, и карточки задач с уровнем и статусом; справа — прогресс по теме и сертификаты, которые её покрывают.

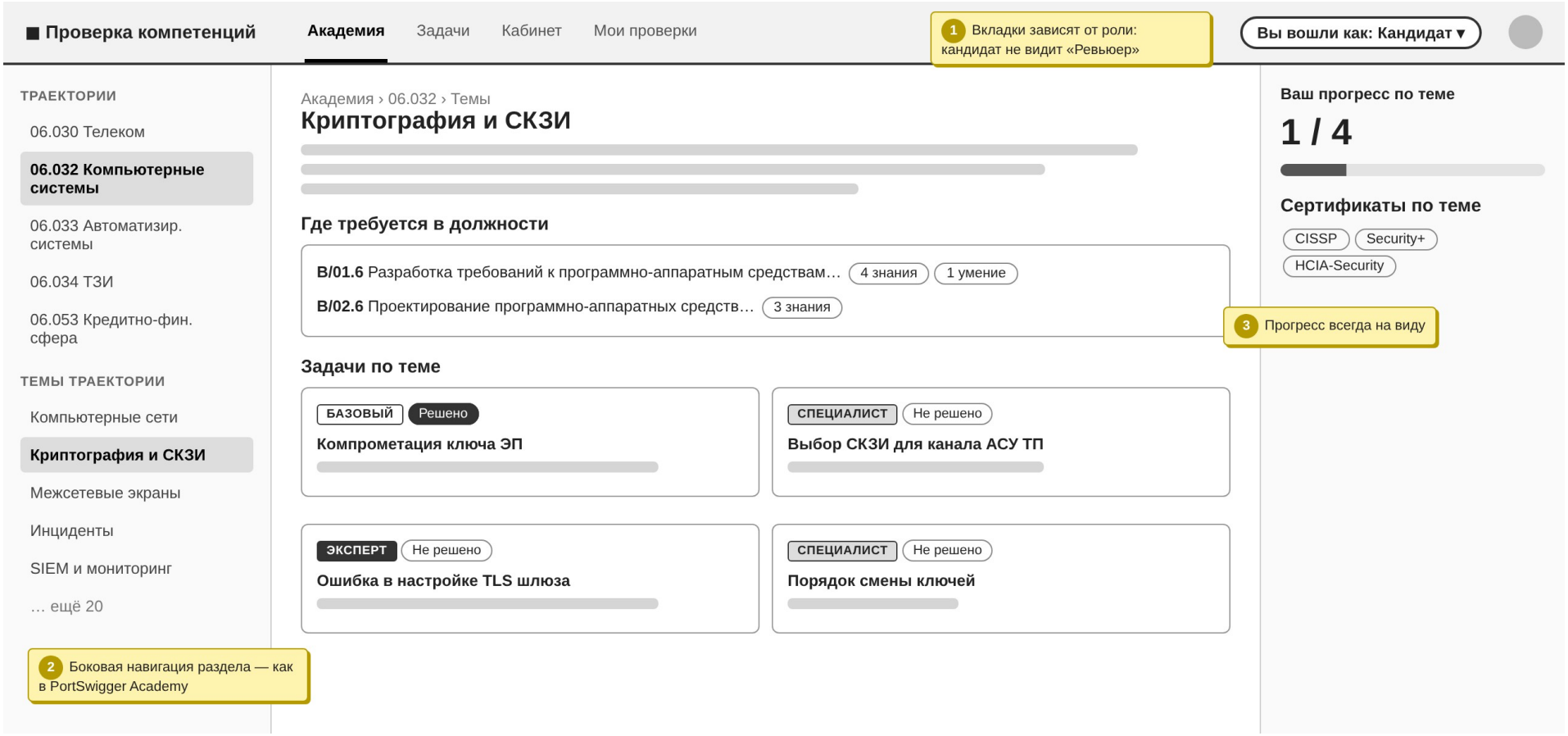


Рисунок 22 — Макет: академия: страница темы

Каталог задач. Аналог списка лабораторных PortSwigger: фильтры по уровню, должности, направлению ОЦК и статусу; в таблице — тема, ТФ, уровень и отметка «решено».

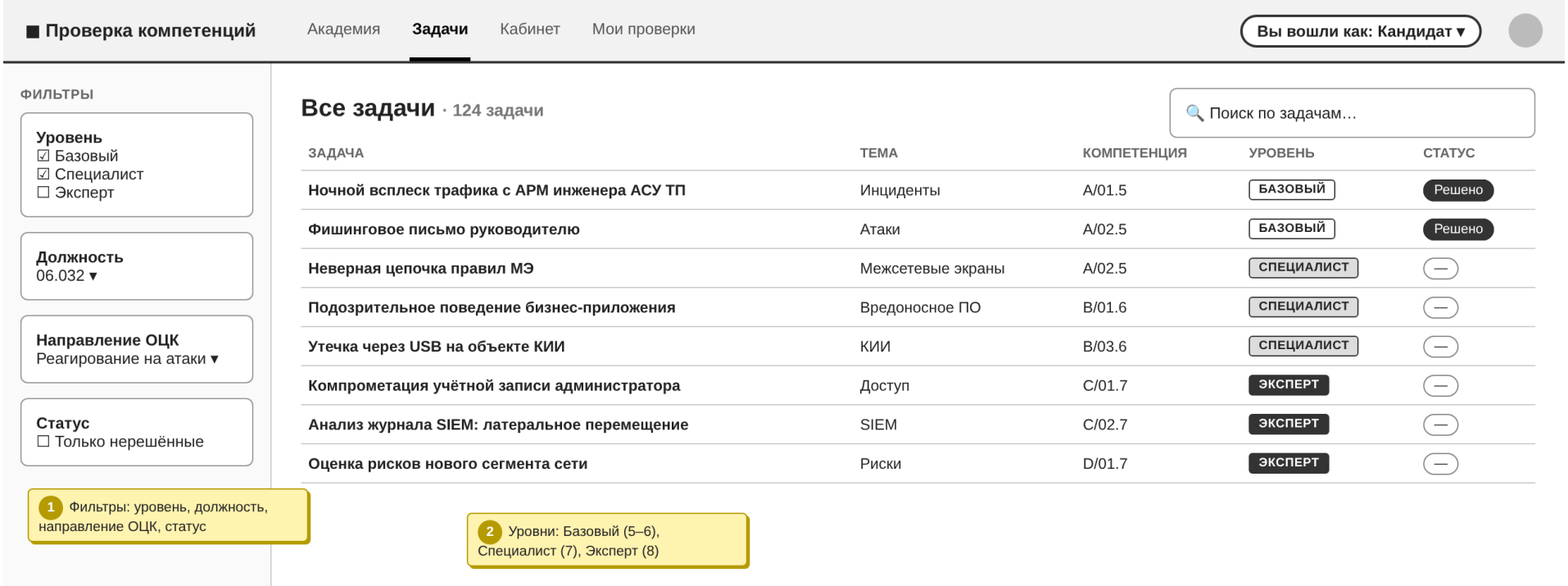


Рисунок 23 — Макет: каталог задач

Выполнение ситуационной задачи. Экран разделён на материалы кейса (вкладки: журнал, схема сети, конфигурация, заявка) и текущий шаг. Шаги идут по одному, полоса прогресса показывает их число; таймер виден, но не давит.

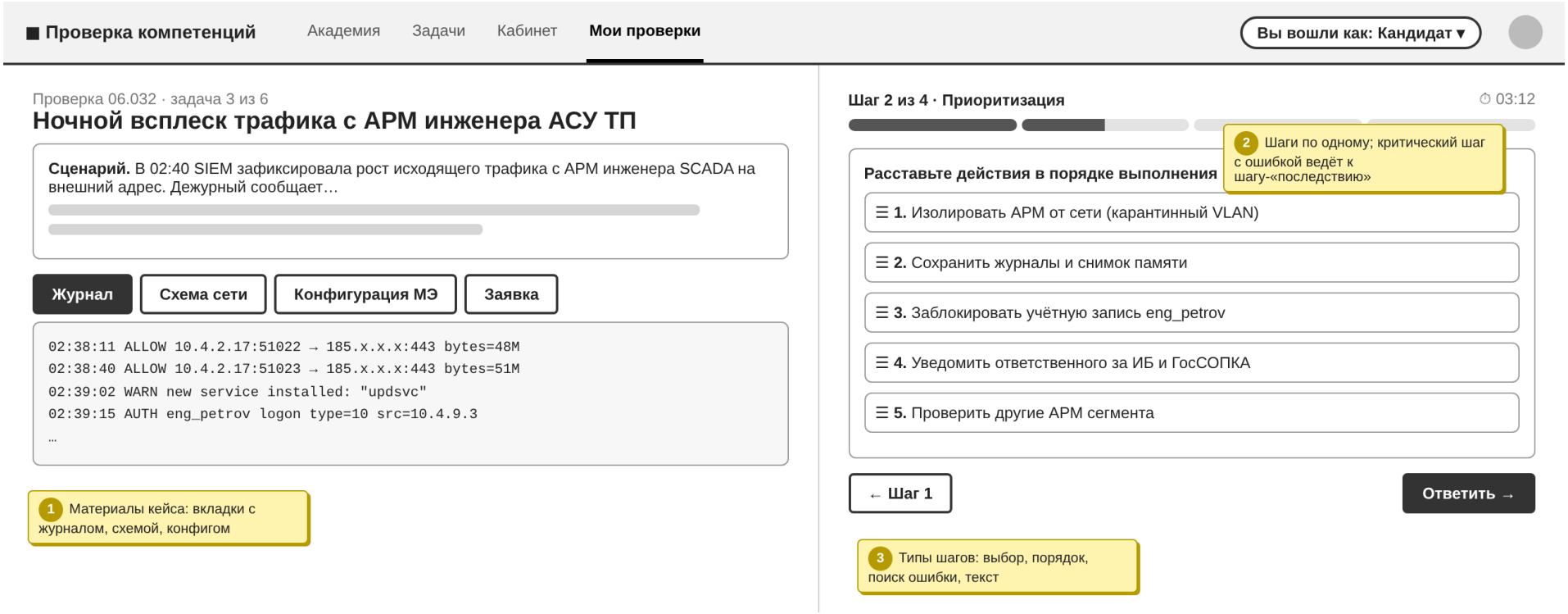


Рисунок 24 — Макет: выполнение ситуационной задачи

Кабинет сотрудника. Итоговая оценка, число решённых задач, подтверждённые сертификаты, уровень; тепловая карта «тема × уровень» и рекомендации, ведущие в Академию.

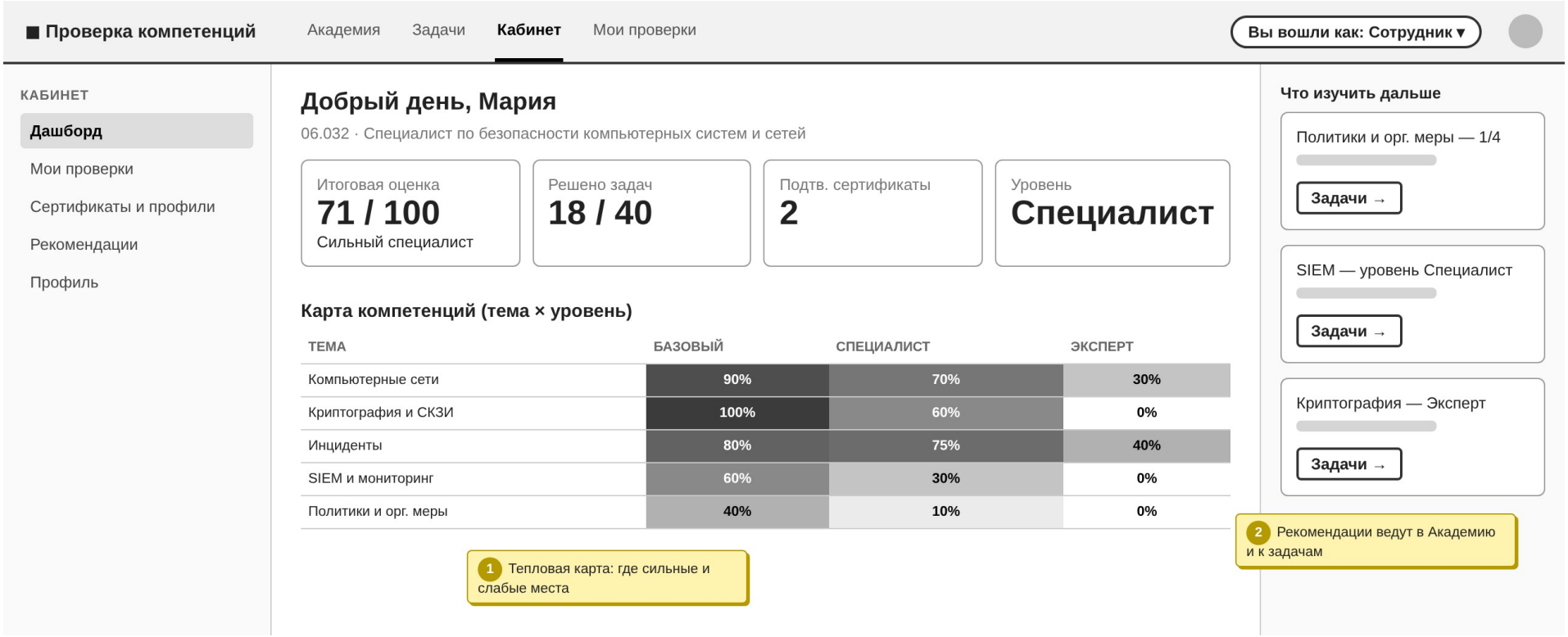


Рисунок 25 — Макет: кабинет сотрудника

Рабочее место ревьюера. Очередь «что ждёт действия» и карточка кандидата: итог с разложением, AI-резюме, развёрнутые ответы к оценке по рубрике. Бейдж «Вы вошли как: Ревьюер» — вкладка «Ревьюер» есть только у этой роли.

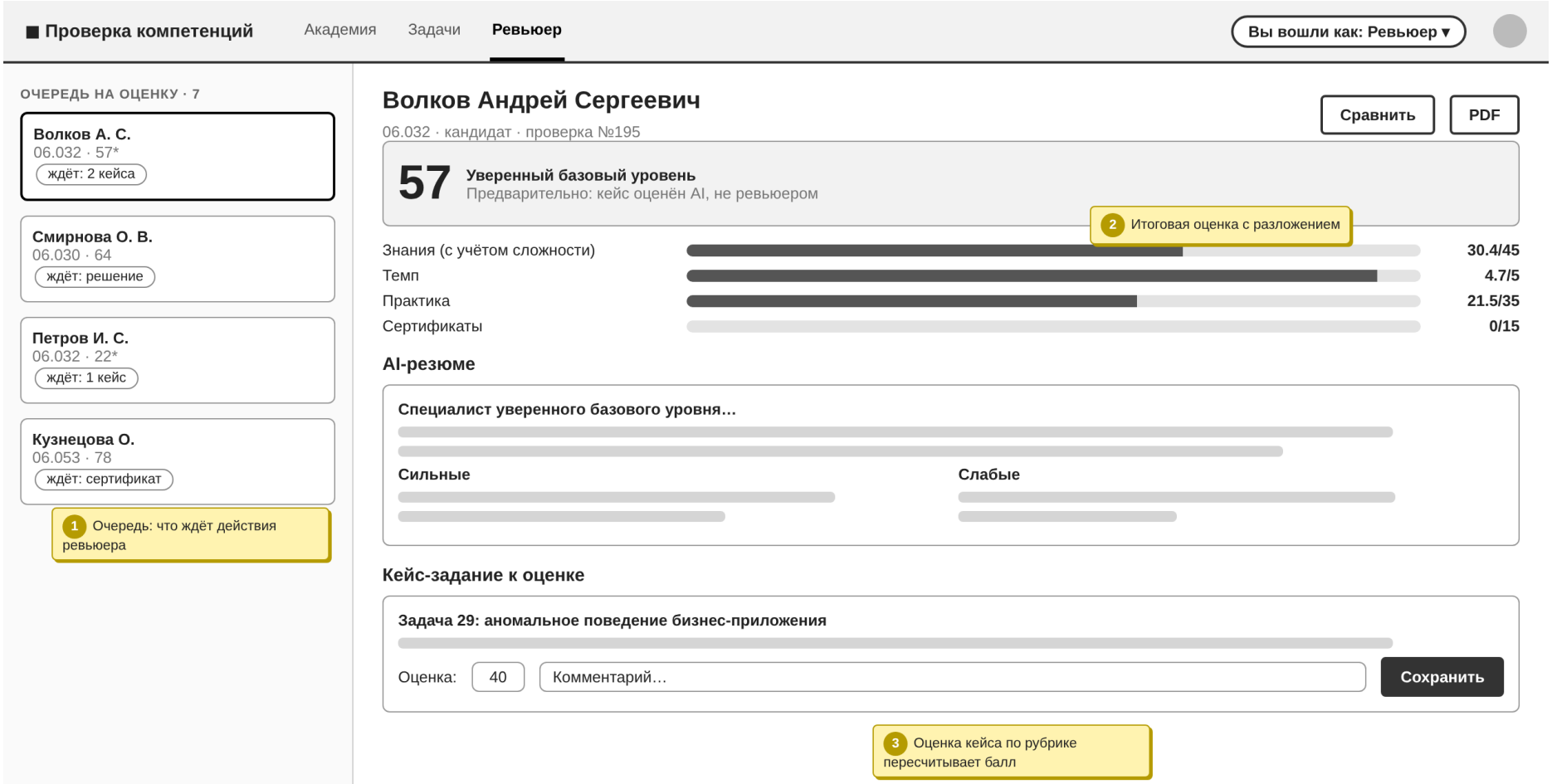


Рисунок 26 — Макет: рабочее место ревьюера

Аналитика ОЦК. Срезы по отрасли, организациям, направлению и периоду; тепловая карта «организация × направление ОЦК»; потребность в подготовке (п. 3.1.20). Пометка об обезличенности данных постоянно видна.

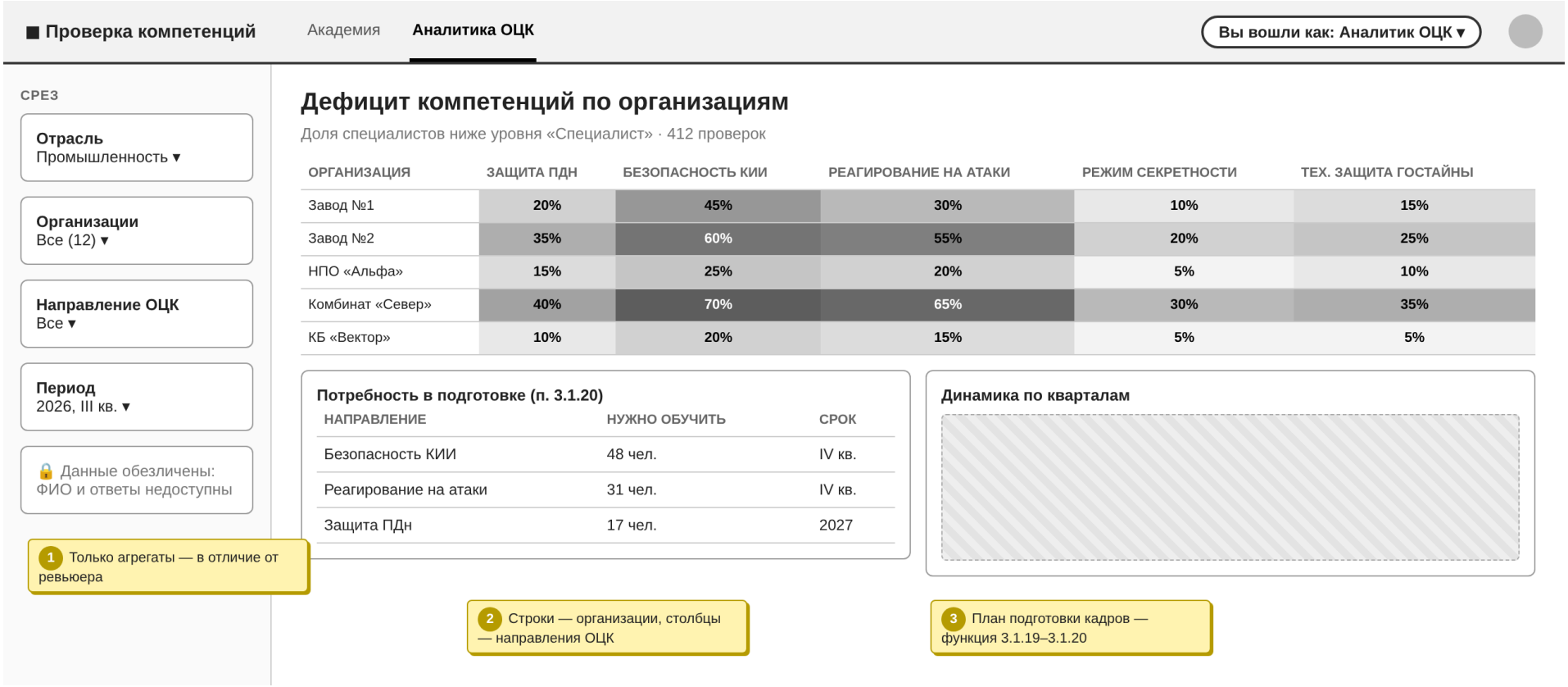


Рисунок 27 — Макет: аналитика оцк

Редактор ситуационной задачи. Название, привязка к ТФ и уровню, сценарий и материалы, список шагов с типами и признаком «критический», шаг-последствие, рубрика текстового шага и темы.

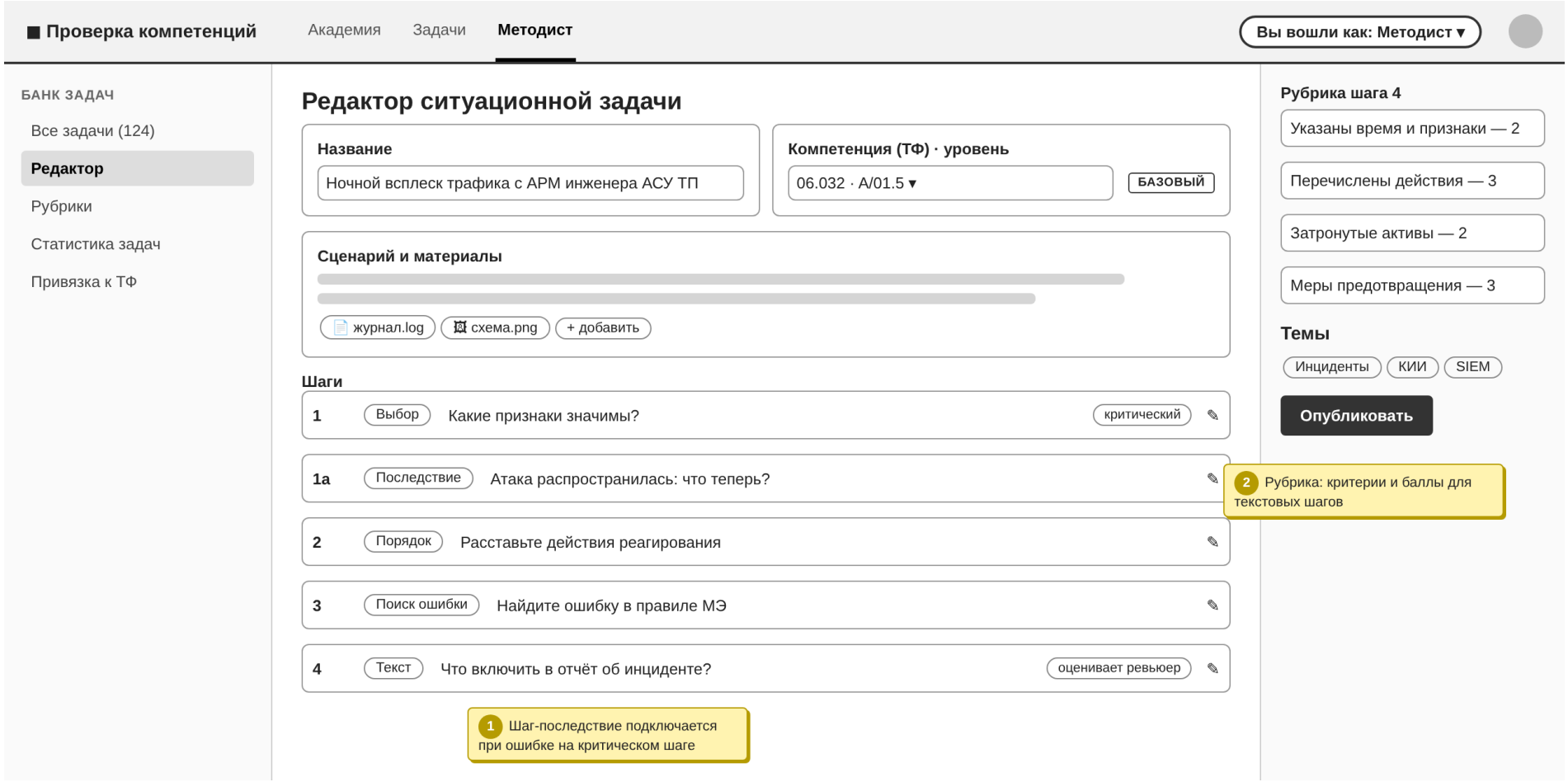


Рисунок 28 — Макет: редактор ситуационной задачи

9 ПЛАН РЕАЛИЗАЦИИ И РИСКИ

9.1 Этапы

Таблица 18 — Этапы реализации

Этап	Содержание	Результат	Оценка
0. Концепция	Настоящий документ: модели, алгоритмы, макеты	Согласованная концепция	выполнено
1. Оболочка и роли	Единая шапка, роли и выбор роли, бейдж, перенос существующих страниц в оболочку	Навигация по ролям в прототипе	2–3 недели
2. Движок задач	Модель SCENARIO*TASK/TASK*STEP, типы шагов, критические шаги и последствия; 20 задач по 06.032	Проверка «разминка + задачи»	4–5 недель
3. Академия	Страницы тем с объяснениями, каталог задач с фильтрами, прогресс	Самостоятельное обучение	3 недели
4. Методист	Редактор задач и рубрик, привязка к ТФ и направлениям ОЦК, статистика задач	Пополнение банка без программиста	3 недели
5. Аналитика ОЦК	Агрегаты с порогом группы, тепловая карта, план подготовки	Модуль для ОЦК	3 недели
6. Пилот	1–2 организации, 50–100 проверок, калибровка сложности и рубрик	Отчёт о пилоте	6 недель

9.2 Критерии готовности PoC

- кандидат проходит проверку «разминка + 3 задачи» без помощи, медианное время — не более 60 минут;
- ревьюер видит итоговую оценку и может объяснить каждый её балл по разложению;
- пользователь в любой момент видит, в какой роли он работает, и не видит разделов чужих ролей;
- аналитик ОЦК получает тепловую карту без единого поля ПДн;
- методист создаёт новую задачу с шагом-последствием без участия разработчика.

9.3 Риски

Таблица 19 — Риски и меры

Риск	Последствие	Мера
Мало качественных задач	Проверка повторяется, ответы утекают	Редактор для методистов, версии задач, ротация, статистика «утёкших» задач по резкому росту доли верных ответов
Субъективность оценки текста	Разные ревьюеры ставят разные баллы	Рубрики с конкретными критериями, AI-оценка как второе мнение, выборочная двойная проверка
Ошибочная привязка сертификата	Завышенная оценка	Подтверждение только ревьюером, сопоставление по хешу e-mail
Восстановление личности по агрегатам	Нарушение конфиденциальности	Порог группы $n \geq 5$, отсутствие ПДн в контуре ОЦК
Неверная калибровка уровней	Несправедливые итоговые оценки	Байесовское уточнение сложности по накопленным ответам, пересмотр после пилота
Зависимость от внешних сервисов	Недоступность OSINT или AI	Асинхронный OSINT, ручной режим AI, оценка без недоступных компонентов

ЗАКЛЮЧЕНИЕ

В документе описан целевой облик платформы проверки компетенций: единая оболочка с навигацией по ролям и явным указанием текущей роли, проверка на основе ситуационных задач с шагами-последствиями, объяснимая итоговая оценка 0–100 и модуль обезличенной аналитики, поддерживающий кадровые функции ОЦК (п. 2.1.6, 3.1.19, 3.1.20 Положения).

Подготовлены модели, необходимые для разработки: функциональные (IDEF0, DFD, варианты использования), алгоритмические (шесть схем по ГОСТ 19.701-90), поведенческие (последовательности и состояния UML), модель данных со словарём, архитектура компонентов и развёртывания, карта разделов и семь макетов экранов. Объёмы проверки (число вопросов разминки, число задач) и границы уровней заданы как настраиваемые параметры и будут уточнены по результатам пилота.

Следующий шаг — этап 1 плана: перенос существующих страниц прототипа в единую оболочку с ролями, после чего — реализация движка ситуационных задач на банке из 20 задач по стандарту 06.032.

ПРИЛОЖЕНИЕ А. ПРИМЕР СИТУАЦИОННОЙ ЗАДАЧИ

Название: Ночной всплеск трафика с АРМ инженера АСУ ТП. **Стандарт / ТФ:** 06.032, A/01.5. **Уровень:** Базовый. **Направление ОЦК:** обнаружение атак и реагирование на инциденты (4.3.1.3). **Темы:** инциденты, КИИ, SIEM. **Время:** ориентировочно 15 минут.

Сценарий. В 02:40 SIEM зафиксировала рост исходящего трафика с АРМ инженера SCADA (10.4.2.17) на внешний адрес по порту 443. Дежурный сообщает, что инженер в отпуске. Материалы: фрагмент журнала межсетевого экрана и Windows, схема сети с сегментами АСУ ТП и корпоративной сети, выгрузка правил межсетевого экрана.

Таблица 20 — Шаги задачи

№	Тип	Задание	Верный ответ / проверка	Баллы
1	Выбор (критический)	Какие признаки в журнале указывают на компрометацию? (выберите все)	Исходящие 48–51 МБ на внешний адрес; установка службы «updsvc»; RDP-вход (type=10) под учётной записью инженера в отпуске. Не значимы: штатные DNS-запросы	4 (по 1 за признак, −1 за лишний)
1а	Последствие	Вы не изолировали АРМ. Через 20 минут в журнале видны подключения 10.4.2.17 к ПЛК по Modbus. Что делаете немедленно?	Изоляция сегмента / АРМ с согласованием с технологом; не отключать ПЛК без технолога	2
2	Порядок	Расставьте действия реагирования	Изолировать АРМ → сохранить журналы и снимок памяти → заблокировать учётную запись → уведомить ответственного за ИБ и ГосСОПКА → проверить другие АРМ сегмента	4 (по согласованным парам)
3	Поиск ошибки	Какое правило межсетевого экрана позволило соединение?	Правило 14: any → any:443 из сегмента АСУ ТП	2
4	Текст	Составьте краткий отчёт об инциденте для руководителя	Рубрика: время и признаки — 2; выполненные действия — 3; затронутые активы — 2; меры предотвращения — 3	10

Шаги 1–3 проверяются автоматически и входят в компонент «Знания» с весом сложности ТФ уровня 5. Шаг 4 оценивает ревьюер по рубрике; балл входит в компонент «Практика». Шаг 1а появляется только при ошибке на шаге 1, и его результат показывается ревьюеру отдельно как признак умения исправлять ошибку.